Reporte de auditoria

@babel/core <=7.29.0

@babel/core: Arbitrary File Read via sourceMappingURL Comment - https://github.com/advisories/GHSA-4x5r-pxfx-6jf8

fix available via `npm audit fix`

node_modules/@babel/core

@babel/plugin-transform-modules-systemjs 7.12.0 - 7.29.0

Severity: high

@babel/plugin-transform-modules-systemjs generates arbitrary code when compiling malicious input - https://github.com/advisories/GHSA-fv7c-fp4j-7gwp

fix available via `npm audit fix`

node_modules/@babel/plugin-transform-modules-systemjs

@capacitor/android 7.0.0 - 7.6.8

Severity: critical

Capacitor Android and iOS: remote content can be loaded at the app origin via the internal HTTP proxy path - https://github.com/advisories/GHSA-rvm3-566m-v7fv

fix available via `npm audit fix`

node_modules/@capacitor/android

@capacitor/ios 7.0.0 - 7.6.8

Severity: critical

Capacitor Android and iOS: remote content can be loaded at the app origin via the internal HTTP proxy path - https://github.com/advisories/GHSA-rvm3-566m-v7fv

fix available via `npm audit fix`

node_modules/@capacitor/ios

@fastify/busboy <=3.2.1

Severity: high

@fastify/busboy vulnerable to Denial of Service via oversized multipart boundary - https://github.com/advisories/GHSA-xjh9-v7x6-24jw

@fastify/busboy vulnerable to Denial of Service via prototype-named multipart part header - https://github.com/advisories/GHSA-x8mw-p69m-v3mx

@fastify/busboy vulnerable to CRLF injection via multipart Content-Disposition filename and name - https://github.com/advisories/GHSA-gxm5-99cw-xjw9

fix available via `npm audit fix`

node_modules/@fastify/busboy

@grpc/grpc-js <=1.13.5 || 1.14.0 - 1.14.4

Severity: high

@grpc/grpc-js: A malformed request can cause a server crash - https://github.com/advisories/GHSA-5375-pq7m-f5r2

@grpc/grpc-js: A malformed request can cause a server crash - https://github.com/advisories/GHSA-5375-pq7m-f5r2

@grpc/grpc-js: An incoming malformed compressed message can cause a client or server crash - https://github.com/advisories/GHSA-99f4-grh7-6pcq

@grpc/grpc-js: An incoming malformed compressed message can cause a client or server crash - https://github.com/advisories/GHSA-99f4-grh7-6pcq

@grpc/grpc-js: In certain configurations, getAuthContext can return unauthorized certificates as though they were authorized - https://github.com/advisories/GHSA-m9gg-hp2v-232j

@grpc/grpc-js: In certain configurations, getAuthContext can return unauthorized certificates as though they were authorized - https://github.com/advisories/GHSA-m9gg-hp2v-232j

@grpc/grpc-js: The server transmits some error messages thrown by method handlers to the client in status messages - https://github.com/advisories/GHSA-f596-whhp-79r4

@grpc/grpc-js: The server transmits some error messages thrown by method handlers to the client in status messages - https://github.com/advisories/GHSA-f596-whhp-79r4

fix available via `npm audit fix`

node_modules/@google-cloud/modelarmor/node_modules/@grpc/grpc-js

node_modules/@grpc/grpc-js

node_modules/google-gax/node_modules/@grpc/grpc-js

@hono/node-server <=1.19.14

Severity: high

@hono/node-server has authorization bypass for protected static paths via encoded slashes in Serve Static Middleware - https://github.com/advisories/GHSA-wc8c-qw6v-h7f6

@hono/node-server: Middleware bypass via repeated slashes in serveStatic - https://github.com/advisories/GHSA-92pp-h63x-v22m

Node.js Adapter for Hono: Path traversal in `serve-static` on Windows via encoded backslash (`%5C`) - https://github.com/advisories/GHSA-frvp-7c67-39w9

fix available via `npm audit fix`

node_modules/@hono/node-server

@isaacs/brace-expansion 5.0.0

Severity: high

@isaacs/brace-expansion has Uncontrolled Resource Consumption - https://github.com/advisories/GHSA-7h2j-956f-4vf2

fix available via `npm audit fix`

node_modules/@isaacs/brace-expansion

@modelcontextprotocol/sdk <=1.31.0

Severity: high

@modelcontextprotocol/sdk has cross-client data leak via shared server/transport instance reuse - https://github.com/advisories/GHSA-345p-7cg4-v4c7

Anthropic's MCP TypeScript SDK has a ReDoS vulnerability - https://github.com/advisories/GHSA-8r9q-7v3j-jr4g

MCP TypeScript SDK: OAuth client could send credentials to an authorization server chosen by the MCP server - https://github.com/advisories/GHSA-6qxp-vccf-f47h

MCP TypeScript SDK: Experimental tasks were not tied to the session that created them - https://github.com/advisories/GHSA-22jm-h49p-29qw

MCP TypeScript SDK: One HTTP request within the default size limit could exhaust server memory during validation - https://github.com/advisories/GHSA-46jr-4wx8-v453

MCP TypeScript SDK: Server bearer authentication accepted tokens issued for another service - https://github.com/advisories/GHSA-rvq5-wwqv-78pq

MCP TypeScript SDK: HTTP server transports and handlers did not limit request body size or JSON-RPC batch length - https://github.com/advisories/GHSA-f897-62hf-6gxq

MCP TypeScript client SDK: HTTP client transports and OAuth requests followed cross-origin redirects and re-sent custom headers and request bodies - https://github.com/advisories/GHSA-6prh-2h8m-c8cw

fix available via `npm audit fix`

node_modules/@modelcontextprotocol/sdk

@opentelemetry/core <2.8.0

Severity: moderate

OpenTelemetry Core: Unbounded memory allocation in W3C Baggage propagation - https://github.com/advisories/GHSA-8988-4f7v-96qf

fix available via `npm audit fix --force`

Will install genkit@0.5.17, which is a breaking change

node_modules/@opentelemetry/core

node_modules/@opentelemetry/exporter-jaeger/node_modules/@opentelemetry/core

node_modules/@opentelemetry/resource-detector-alibaba-cloud/node_modules/@opentelemetry/core

node_modules/@opentelemetry/resource-detector-container/node_modules/@opentelemetry/core

@genkit-ai/core *

Depends on vulnerable versions of @genkit-ai/firebase

Depends on vulnerable versions of @opentelemetry/core

Depends on vulnerable versions of @opentelemetry/exporter-jaeger

Depends on vulnerable versions of @opentelemetry/sdk-metrics

Depends on vulnerable versions of @opentelemetry/sdk-node

Depends on vulnerable versions of @opentelemetry/sdk-trace-base

Depends on vulnerable versions of zod

node_modules/@genkit-ai/core

@genkit-ai/ai *

Depends on vulnerable versions of @genkit-ai/core

Depends on vulnerable versions of uuid

node_modules/@genkit-ai/ai

genkit <=0.5.0-rc.12 || 0.6.0-dev.2 - 1.0.0-rc.19 || >=1.0.4

Depends on vulnerable versions of @genkit-ai/ai

Depends on vulnerable versions of @genkit-ai/core

Depends on vulnerable versions of uuid

node_modules/genkit

@genkit-ai/google-cloud *

Depends on vulnerable versions of @google-cloud/opentelemetry-cloud-monitoring-exporter

Depends on vulnerable versions of @opentelemetry/auto-instrumentations-node

Depends on vulnerable versions of @opentelemetry/core

Depends on vulnerable versions of @opentelemetry/instrumentation-pino

Depends on vulnerable versions of @opentelemetry/resources

Depends on vulnerable versions of @opentelemetry/sdk-metrics

Depends on vulnerable versions of @opentelemetry/sdk-node

Depends on vulnerable versions of @opentelemetry/sdk-trace-base

node_modules/@genkit-ai/google-cloud

@genkit-ai/firebase >=0.5.4

Depends on vulnerable versions of @genkit-ai/google-cloud

node_modules/@genkit-ai/firebase

@genkit-ai/telemetry-server >=0.9.0-dev.1

Depends on vulnerable versions of @genkit-ai/tools-common

Depends on vulnerable versions of @google-cloud/firestore

Depends on vulnerable versions of @opentelemetry/core

Depends on vulnerable versions of @opentelemetry/sdk-metrics

Depends on vulnerable versions of @opentelemetry/sdk-node

Depends on vulnerable versions of @opentelemetry/sdk-trace-base

Depends on vulnerable versions of zod

node_modules/@genkit-ai/telemetry-server

@opentelemetry/exporter-jaeger *

Depends on vulnerable versions of @opentelemetry/core

Depends on vulnerable versions of @opentelemetry/sdk-trace-base

Depends on vulnerable versions of jaeger-client

node_modules/@opentelemetry/exporter-jaeger

@opentelemetry/exporter-trace-otlp-grpc <=0.218.0

Depends on vulnerable versions of @opentelemetry/core

Depends on vulnerable versions of @opentelemetry/otlp-grpc-exporter-base

Depends on vulnerable versions of @opentelemetry/otlp-transformer

Depends on vulnerable versions of @opentelemetry/resources

Depends on vulnerable versions of @opentelemetry/sdk-trace-base

node_modules/@opentelemetry/exporter-trace-otlp-grpc

@opentelemetry/sdk-node <=0.218.0

Depends on vulnerable versions of @opentelemetry/core

Depends on vulnerable versions of @opentelemetry/exporter-trace-otlp-grpc

Depends on vulnerable versions of @opentelemetry/exporter-trace-otlp-http

Depends on vulnerable versions of @opentelemetry/exporter-trace-otlp-proto

Depends on vulnerable versions of @opentelemetry/exporter-zipkin

Depends on vulnerable versions of @opentelemetry/resources

Depends on vulnerable versions of @opentelemetry/sdk-logs

Depends on vulnerable versions of @opentelemetry/sdk-metrics

Depends on vulnerable versions of @opentelemetry/sdk-trace-base

Depends on vulnerable versions of @opentelemetry/sdk-trace-node

node_modules/@opentelemetry/sdk-node

@opentelemetry/auto-instrumentations-node <=0.78.0

Depends on vulnerable versions of @opentelemetry/instrumentation-amqplib

Depends on vulnerable versions of @opentelemetry/instrumentation-aws-lambda

Depends on vulnerable versions of @opentelemetry/instrumentation-aws-sdk

Depends on vulnerable versions of @opentelemetry/instrumentation-cassandra-driver

Depends on vulnerable versions of @opentelemetry/instrumentation-connect

Depends on vulnerable versions of @opentelemetry/instrumentation-express

Depends on vulnerable versions of @opentelemetry/instrumentation-fastify

Depends on vulnerable versions of @opentelemetry/instrumentation-fs

Depends on vulnerable versions of @opentelemetry/instrumentation-hapi

Depends on vulnerable versions of @opentelemetry/instrumentation-http

Depends on vulnerable versions of @opentelemetry/instrumentation-knex

Depends on vulnerable versions of @opentelemetry/instrumentation-koa

Depends on vulnerable versions of @opentelemetry/instrumentation-mongodb

Depends on vulnerable versions of @opentelemetry/instrumentation-mongoose

Depends on vulnerable versions of @opentelemetry/instrumentation-mysql

Depends on vulnerable versions of @opentelemetry/instrumentation-mysql2

Depends on vulnerable versions of @opentelemetry/instrumentation-pg

Depends on vulnerable versions of @opentelemetry/instrumentation-pino

Depends on vulnerable versions of @opentelemetry/instrumentation-restify

Depends on vulnerable versions of @opentelemetry/instrumentation-tedious

Depends on vulnerable versions of @opentelemetry/instrumentation-undici

Depends on vulnerable versions of @opentelemetry/resource-detector-aws

Depends on vulnerable versions of @opentelemetry/resource-detector-azure

Depends on vulnerable versions of @opentelemetry/resource-detector-gcp

Depends on vulnerable versions of @opentelemetry/resources

Depends on vulnerable versions of @opentelemetry/sdk-node

node_modules/@opentelemetry/auto-instrumentations-node

@opentelemetry/exporter-trace-otlp-http <=0.218.0

Depends on vulnerable versions of @opentelemetry/core

Depends on vulnerable versions of @opentelemetry/otlp-exporter-base

Depends on vulnerable versions of @opentelemetry/otlp-transformer

Depends on vulnerable versions of @opentelemetry/resources

Depends on vulnerable versions of @opentelemetry/sdk-trace-base

node_modules/@opentelemetry/exporter-trace-otlp-http

@opentelemetry/exporter-trace-otlp-proto <=0.218.0

Depends on vulnerable versions of @opentelemetry/core

Depends on vulnerable versions of @opentelemetry/otlp-exporter-base

Depends on vulnerable versions of @opentelemetry/otlp-transformer

Depends on vulnerable versions of @opentelemetry/resources

Depends on vulnerable versions of @opentelemetry/sdk-trace-base

node_modules/@opentelemetry/exporter-trace-otlp-proto

@opentelemetry/exporter-zipkin <=2.7.1

Depends on vulnerable versions of @opentelemetry/core

Depends on vulnerable versions of @opentelemetry/resources

Depends on vulnerable versions of @opentelemetry/sdk-trace-base

node_modules/@opentelemetry/exporter-zipkin

@opentelemetry/instrumentation-amqplib <=0.46.1

Depends on vulnerable versions of @opentelemetry/core

node_modules/@opentelemetry/instrumentation-amqplib

@opentelemetry/instrumentation-aws-sdk <=0.49.1

Depends on vulnerable versions of @opentelemetry/core

node_modules/@opentelemetry/instrumentation-aws-sdk

@opentelemetry/instrumentation-connect <=0.43.1

Depends on vulnerable versions of @opentelemetry/core

node_modules/@opentelemetry/instrumentation-connect

@opentelemetry/instrumentation-express <=0.47.1

Depends on vulnerable versions of @opentelemetry/core

node_modules/@opentelemetry/instrumentation-express

@opentelemetry/instrumentation-fastify <=0.44.2

Depends on vulnerable versions of @opentelemetry/core

node_modules/@opentelemetry/instrumentation-fastify

@opentelemetry/instrumentation-fs <=0.19.1

Depends on vulnerable versions of @opentelemetry/core

node_modules/@opentelemetry/instrumentation-fs

@opentelemetry/instrumentation-hapi 0.24.0 - 0.45.2

Depends on vulnerable versions of @opentelemetry/core

node_modules/@opentelemetry/instrumentation-hapi

@opentelemetry/instrumentation-http <=0.16.0 || 0.19.1-alpha.7 - 0.218.0

Depends on vulnerable versions of @opentelemetry/core

node_modules/@opentelemetry/instrumentation-http

@opentelemetry/instrumentation-koa <=0.15.0 || 0.20.0 - 0.47.1

Depends on vulnerable versions of @opentelemetry/core

node_modules/@opentelemetry/instrumentation-koa

@opentelemetry/instrumentation-mongoose <=0.66.0

Depends on vulnerable versions of @opentelemetry/core

node_modules/@opentelemetry/instrumentation-mongoose

@opentelemetry/instrumentation-pino 0.41.0 - 0.46.1

Depends on vulnerable versions of @opentelemetry/core

node_modules/@opentelemetry/instrumentation-pino

@opentelemetry/instrumentation-restify 0.20.0 - 0.45.1

Depends on vulnerable versions of @opentelemetry/core

node_modules/@opentelemetry/instrumentation-restify

@opentelemetry/instrumentation-undici <=0.10.1

Depends on vulnerable versions of @opentelemetry/core

node_modules/@opentelemetry/instrumentation-undici

@opentelemetry/otlp-exporter-base <=0.218.0

Depends on vulnerable versions of @opentelemetry/core

Depends on vulnerable versions of @opentelemetry/otlp-transformer

node_modules/@opentelemetry/otlp-exporter-base

@opentelemetry/otlp-grpc-exporter-base <=0.218.0

Depends on vulnerable versions of @opentelemetry/core

Depends on vulnerable versions of @opentelemetry/otlp-exporter-base

Depends on vulnerable versions of @opentelemetry/otlp-transformer

node_modules/@opentelemetry/otlp-grpc-exporter-base

@opentelemetry/otlp-transformer <=0.218.0

Depends on vulnerable versions of @opentelemetry/core

Depends on vulnerable versions of @opentelemetry/resources

Depends on vulnerable versions of @opentelemetry/sdk-logs

Depends on vulnerable versions of @opentelemetry/sdk-metrics

Depends on vulnerable versions of @opentelemetry/sdk-trace-base

node_modules/@opentelemetry/otlp-transformer

@opentelemetry/propagator-b3 0.19.1-alpha.11 - 2.7.1

Depends on vulnerable versions of @opentelemetry/core

node_modules/@opentelemetry/propagator-b3

@opentelemetry/propagator-jaeger <=2.8.0

Depends on vulnerable versions of @opentelemetry/core

node_modules/@opentelemetry/propagator-jaeger

@opentelemetry/sdk-trace-node <=2.7.1

Depends on vulnerable versions of @opentelemetry/core

Depends on vulnerable versions of @opentelemetry/propagator-b3

Depends on vulnerable versions of @opentelemetry/propagator-jaeger

Depends on vulnerable versions of @opentelemetry/sdk-trace-base

node_modules/@opentelemetry/sdk-trace-node

@opentelemetry/resource-detector-alibaba-cloud <=0.30.1

Depends on vulnerable versions of @opentelemetry/core

Depends on vulnerable versions of @opentelemetry/resources

node_modules/@opentelemetry/resource-detector-alibaba-cloud

@opentelemetry/resource-detector-aws <=1.12.0

Depends on vulnerable versions of @opentelemetry/core

Depends on vulnerable versions of @opentelemetry/resources

node_modules/@opentelemetry/resource-detector-aws

@opentelemetry/resource-detector-azure <=0.6.1

Depends on vulnerable versions of @opentelemetry/core

Depends on vulnerable versions of @opentelemetry/resources

node_modules/@opentelemetry/resource-detector-azure

@opentelemetry/resource-detector-container <=0.6.1

Depends on vulnerable versions of @opentelemetry/core

Depends on vulnerable versions of @opentelemetry/resources

node_modules/@opentelemetry/resource-detector-container

@opentelemetry/resource-detector-gcp <=0.33.1

Depends on vulnerable versions of @opentelemetry/core

Depends on vulnerable versions of @opentelemetry/resources

node_modules/@opentelemetry/resource-detector-gcp

@opentelemetry/resources 0.8.0 - 2.7.1

Depends on vulnerable versions of @opentelemetry/core

node_modules/@opentelemetry/exporter-jaeger/node_modules/@opentelemetry/resources

node_modules/@opentelemetry/resources

@opentelemetry/instrumentation-aws-lambda <=0.45.0

Depends on vulnerable versions of @opentelemetry/resources

node_modules/@opentelemetry/instrumentation-aws-lambda

@opentelemetry/sdk-logs <=0.218.0

Depends on vulnerable versions of @opentelemetry/core

Depends on vulnerable versions of @opentelemetry/resources

node_modules/@opentelemetry/sdk-logs

@opentelemetry/sdk-metrics <=2.7.1

Depends on vulnerable versions of @opentelemetry/core

Depends on vulnerable versions of @opentelemetry/resources

node_modules/@opentelemetry/sdk-metrics

@opentelemetry/instrumentation-mongodb 0.35.0 - 0.47.0

Depends on vulnerable versions of @opentelemetry/sdk-metrics

node_modules/@opentelemetry/instrumentation-mongodb

@opentelemetry/sdk-trace-base <=2.7.1

Depends on vulnerable versions of @opentelemetry/core

Depends on vulnerable versions of @opentelemetry/resources

node_modules/@opentelemetry/exporter-jaeger/node_modules/@opentelemetry/sdk-trace-base

node_modules/@opentelemetry/sdk-trace-base

@opentelemetry/sql-common <=0.40.1

Depends on vulnerable versions of @opentelemetry/core

node_modules/@opentelemetry/sql-common

@opentelemetry/instrumentation-mysql2 <=0.66.0

Depends on vulnerable versions of @opentelemetry/sql-common

node_modules/@opentelemetry/instrumentation-mysql2

@opentelemetry/instrumentation-pg <=0.72.0

Depends on vulnerable versions of @opentelemetry/sql-common

node_modules/@opentelemetry/instrumentation-pg

@opentelemetry/instrumentation-cassandra-driver <0.66.0

Severity: moderate

Multiple @opentelemetry/instrumentation-* packages expose database username via unconditional db.user span attribute - https://github.com/advisories/GHSA-qqmp-wf37-98f9

fix available via `npm audit fix`

node_modules/@opentelemetry/instrumentation-cassandra-driver

@opentelemetry/instrumentation-knex <0.65.0

Severity: moderate

Multiple @opentelemetry/instrumentation-* packages expose database username via unconditional db.user span attribute - https://github.com/advisories/GHSA-qqmp-wf37-98f9

fix available via `npm audit fix`

node_modules/@opentelemetry/instrumentation-knex

@opentelemetry/instrumentation-mysql <0.67.0

Severity: moderate

Multiple @opentelemetry/instrumentation-* packages expose database username via unconditional db.user span attribute - https://github.com/advisories/GHSA-qqmp-wf37-98f9

fix available via `npm audit fix`

node_modules/@opentelemetry/instrumentation-mysql

@opentelemetry/instrumentation-tedious <0.40.0

Severity: moderate

Multiple @opentelemetry/instrumentation-* packages expose database username via unconditional db.user span attribute - https://github.com/advisories/GHSA-qqmp-wf37-98f9

fix available via `npm audit fix`

node_modules/@opentelemetry/instrumentation-tedious

@protobufjs/utf8 <=1.1.0

Severity: moderate

protobufjs has overlong UTF-8 decoding - https://github.com/advisories/GHSA-q6x5-8v7m-xcrf

fix available via `npm audit fix`

node_modules/@protobufjs/utf8

@tiptap/core <=3.30.4

Severity: high

Tiptap: mergeAttributes() turns an own __proto__ key into inherited executable DOM attributes - https://github.com/advisories/GHSA-cp6q-959q-f8rh

Tiptap: Quadratic ReDoS in block and inline Markdown attribute parsing - https://github.com/advisories/GHSA-j95f-988m-3j2f

fix available via `npm audit fix`

node_modules/@tiptap/core

@tootallnate/once <2.0.1

@tootallnate/once vulnerable to Incorrect Control Flow Scoping - https://github.com/advisories/GHSA-vpq2-c234-7xj6

fix available via `npm audit fix`

node_modules/@tootallnate/once

@xmldom/xmldom <=0.8.14

Severity: high

xmldom: XML injection via unsafe CDATA serialization allows attacker-controlled markup insertion - https://github.com/advisories/GHSA-wh4c-j3r5-mjhp

xmldom: Uncontrolled recursion in XML serialization leads to DoS - https://github.com/advisories/GHSA-2v35-w6hq-6mfw

xmldom has XML injection through unvalidated DocumentType serialization - https://github.com/advisories/GHSA-f6ww-3ggp-fr8h

xmldom has XML node injection through unvalidated processing instruction serialization - https://github.com/advisories/GHSA-x6wf-f3px-wcqx

xmldom has XML node injection through unvalidated comment serialization - https://github.com/advisories/GHSA-j759-j44w-7fr8

xmldom: XML fragment injection via invalid EntityReference.nodeName during requireWellFormed serialization - https://github.com/advisories/GHSA-6gmq-8vp8-gcm6

xmldom: Element name injection via createElement() bypasses requireWellFormed - https://github.com/advisories/GHSA-w2rr-34g9-rvrj

xmldom: Attribute name injection via setAttribute() bypasses requireWellFormed - https://github.com/advisories/GHSA-4w3w-2rp5-g8jm

xmldom: Processing Instruction Target Injection Bypasses requireWellFormed - https://github.com/advisories/GHSA-c7q8-3ch8-vqpv

xmldom: DocType `name` Injection Bypasses requireWellFormed - https://github.com/advisories/GHSA-27p8-2357-5qqv

xmldom: Parser silently accepts a not-well-formed end tag whose name is followed by a line break and trailing content - https://github.com/advisories/GHSA-6h8r-xr42-gp59

xmldom: Quadratic-time attribute deduplication - https://github.com/advisories/GHSA-8344-3jmq-59r6

xmldom: End-tag Whitespace-Trim Regex ReDoS — quadratic backtracking in the 0.8.x end-tag parser - https://github.com/advisories/GHSA-x4fp-j954-r2f4

xmldom: Quadratic-memory consumption - https://github.com/advisories/GHSA-965w-775f-mr7g

xmldom: Quadratic-time parsing via the malformed-input recovery path — `parseElementStartPart` re-scan and `normalize()` adjacent-text merge - https://github.com/advisories/GHSA-93r5-fhx6-vmg9

fix available via `npm audit fix`

node_modules/@xmldom/xmldom

adm-zip <=0.6.0

Severity: high

adm-zip: Crafted ZIP file triggers 4GB memory allocation - https://github.com/advisories/GHSA-xcpc-8h2w-3j85

adm-zip extraction follows destination symlinks, allowing arbitrary file overwrite - https://github.com/advisories/GHSA-vwc7-r8mq-g2x9

adm-zip: Uncontrolled memory allocation via the declared uncompressed size (DoS) - https://github.com/advisories/GHSA-7q85-xj36-vmfc

adm-zip: Decompression-bomb protection (fix for CVE-2026-39244) can be bypassed by declaring uncompressed size as 0 - https://github.com/advisories/GHSA-rcw4-f5rp-g42v

adm-zip extraction preserves SUID/SGID bits from untrusted ZIPs -> local privilege escalation - https://github.com/advisories/GHSA-j5f4-cc29-5x44

adm-zip: Duplicate ZIP entry names: getEntry() and extractAllTo() resolve to different content - https://github.com/advisories/GHSA-p634-w6r4-rjp2

adm-zip: getDataAsync() bypasses the maxOutputLength size guard enforced by the synchronous getData() path - https://github.com/advisories/GHSA-c6fg-446q-cg94

adm-zip: Unhandled error event in async DEFLATE decompression crashes Node.js process (DoS) - https://github.com/advisories/GHSA-8238-w5pm-2374

fix available via `npm audit fix`

node_modules/adm-zip

ajv <6.14.0 || >=7.0.0-alpha.0 <8.18.0

Severity: moderate

ajv has ReDoS when using `$data` option - https://github.com/advisories/GHSA-2g4f-4pwh-qvx6

ajv has ReDoS when using `$data` option - https://github.com/advisories/GHSA-2g4f-4pwh-qvx6

fix available via `npm audit fix`

node_modules/ajv

node_modules/schema-utils/node_modules/ajv

axios 1.0.0 - 1.19.0

Severity: high

Axios has a NO_PROXY Hostname Normalization Bypass that Leads to SSRF - https://github.com/advisories/GHSA-3p68-rc4w-qgx5

Axios: Authentication Bypass via Prototype Pollution Gadget in `validateStatus` Merge Strategy - https://github.com/advisories/GHSA-w9j2-pvgh-6h63

Axios: Incomplete Fix for CVE-2025-62718 — NO_PROXY Protection Bypassed via RFC 1122 Loopback Subnet (127.0.0.0/8) in Axios 1.15.0 - https://github.com/advisories/GHSA-pmwg-cvhr-8vh7

Axios: Invisible JSON Response Tampering via Prototype Pollution Gadget in `parseReviver` - https://github.com/advisories/GHSA-3w6x-2g7m-8v23

Axios: Null Byte Injection via Reverse-Encoding in AxiosURLSearchParams - https://github.com/advisories/GHSA-xhjh-pmcv-23jw

Axios: CRLF Injection in multipart/form-data body via unsanitized blob.type in formDataToStream - https://github.com/advisories/GHSA-445q-vr5w-6q77

Axios: no_proxy bypass via IP alias allows SSRF - https://github.com/advisories/GHSA-m7pr-hjqh-92cm

Axios' HTTP adapter-streamed uploads bypass maxBodyLength when maxRedirects: 0 - https://github.com/advisories/GHSA-5c9x-8gcm-mpgx

Axios: HTTP adapter streamed responses bypass maxContentLength - https://github.com/advisories/GHSA-vf2m-468p-8v99

Axios: Prototype Pollution Gadgets - Response Tampering, Data Exfiltration, and Request Hijacking - https://github.com/advisories/GHSA-pf86-5x62-jrwf

Axios: Header Injection via Prototype Pollution - https://github.com/advisories/GHSA-6chq-wfr3-2hj9

Axios: XSRF Token Cross-Origin Leakage via Prototype Pollution Gadget in `withXSRFToken` Boolean Coercion - https://github.com/advisories/GHSA-xx6v-rp6x-q39c

Axios is Vulnerable to Denial of Service via __proto__ Key in mergeConfig - https://github.com/advisories/GHSA-43fc-jf86-j433

Axios has prototype pollution read-side gadgets in HTTP adapter that allow credential injection and request hijacking - https://github.com/advisories/GHSA-q8qp-cvcw-x6jj

Axios has Unrestricted Cloud Metadata Exfiltration via Header Injection Chain - https://github.com/advisories/GHSA-fvcv-3m26-pcqx

Axios: unbounded recursion in toFormData causes DoS via deeply nested request data - https://github.com/advisories/GHSA-62hf-57xw-28j9

Axios: Regular Expression Denial of Service (ReDoS) via Cookie Name Injection - https://github.com/advisories/GHSA-hfxv-24rg-xrqf

Allocation of Resources Without Limits or Throttling in Axios - https://github.com/advisories/GHSA-777c-7fjr-54vf

Axios: Proxy-Authorization Credential Leak to Origin Server Across HTTP-to-HTTPS Redirect in Axios Node.js HTTP Adapter - https://github.com/advisories/GHSA-p92q-9vqr-4j8v

Axios: Proxy-Authorization header leaks to redirect target when proxy is re-evaluated to direct connection - https://github.com/advisories/GHSA-j5f8-grm9-p9fc

axios Vulnerable to Credential Theft and Response Hijacking via Prototype Pollution Gadget in Config Merge - https://github.com/advisories/GHSA-3g43-6gmg-66jw

axios Vulnerable to Full Man-in-the-Middle via Prototype Pollution Gadget in `config.proxy` - https://github.com/advisories/GHSA-35jp-ww65-95wh

axios has DoS & Header Injection via Prototype Pollution Read-Side Gadgets in axios merge functions - https://github.com/advisories/GHSA-898c-q2cr-xwhg

Axios: Prototype pollution gadgets can alter axios request construction - https://github.com/advisories/GHSA-mmx7-hfxf-jppx

Axios: Deep formToJSON Key Recursion Can Cause Denial of Service - https://github.com/advisories/GHSA-pmv8-rq9r-6j72

Axios: HTTP/2 streamed uploads bypass `maxBodyLength` - https://github.com/advisories/GHSA-mwf2-3pr3-8698

Axios: Nested axios option objects can consume polluted prototype values - https://github.com/advisories/GHSA-7q8q-rj6j-mhjq

Axios: Fetch adapter `ReadableStream` uploads bypass `maxBodyLength` - https://github.com/advisories/GHSA-jqh4-m9w3-8hp9

Axios: Excessive recursion in formDataToJSON can cause denial of service - https://github.com/advisories/GHSA-42h9-826w-cgv3

Axios: Prototype pollution gadget in fetch adapter can alter outbound requests - https://github.com/advisories/GHSA-vh66-26gq-q6x8

Axios: Prototype-Pollution Gadget in the Default Instance Allows Inherited Object.prototype.method to Override HTTP Method - https://github.com/advisories/GHSA-9fr6-4gfg-395g

Axios: HTTP/2 adapter bypasses configured DNS lookup and proxy controls - https://github.com/advisories/GHSA-3pq3-5fj3-cg6v

Axios: Denial of Service via Unhandled 'error' Event in HTTP/2 ClientHttp2Session Initialization - https://github.com/advisories/GHSA-542g-h47m-68v8

Axios: Header Injection via Inherited headers After Minimal Interceptor - https://github.com/advisories/GHSA-j8rh-479h-cp32

Axios: Fetch Adapter Header Injection via Inherited FormData getHeaders - https://github.com/advisories/GHSA-4hqw-qxg8-jxx2

fix available via `npm audit fix`

node_modules/axios

baseline-browser-mapping >=2.0.0 <2.11.0

Severity: moderate

baseline-browser-mapping process termination on invalid input causes denial of service - https://github.com/advisories/GHSA-w5vr-8v7q-w6rv

fix available via `npm audit fix`

node_modules/baseline-browser-mapping

basic-ftp <=6.2.0

Severity: critical

Basic FTP has Path Traversal Vulnerability in its downloadToDir() method - https://github.com/advisories/GHSA-5rq4-664w-9x2c

basic-ftp: Incomplete CRLF Injection Protection Allows Arbitrary FTP Command Execution via Credentials and MKD Commands - https://github.com/advisories/GHSA-6v7q-wjvx-w8wg

basic-ftp vulnerable to denial of service via unbounded memory consumption in Client.list() - https://github.com/advisories/GHSA-rp42-5vxx-qpwr

basic-ftp allows a malicious FTP server to cause client-side denial of service via unbounded multiline control response buffering - https://github.com/advisories/GHSA-rpmf-866q-6p89

basic-ftp: Quadratic-time CPU denial of service in Client.list() Unix directory-listing parser (RE_LINE backtracking) - https://github.com/advisories/GHSA-c475-qrg2-pj4r

fix available via `npm audit fix`

node_modules/basic-ftp

body-parser <=1.20.8 || 2.0.0-beta.1 - 2.3.0

Severity: high

body-parser vulnerable to denial of service when invalid limit value silently disables size enforcement - https://github.com/advisories/GHSA-v422-hmwv-36x6

body-parser vulnerable to denial of service when invalid limit value silently disables size enforcement - https://github.com/advisories/GHSA-v422-hmwv-36x6

body-parser vulnerable to Denial of Service via trailing bytes after a compressed request body - https://github.com/advisories/GHSA-27r3-jxmh-p828

body-parser vulnerable to Denial of Service via trailing bytes after a compressed request body - https://github.com/advisories/GHSA-27r3-jxmh-p828

Depends on vulnerable versions of qs

fix available via `npm audit fix`

node_modules/@modelcontextprotocol/sdk/node_modules/body-parser

node_modules/body-parser

brace-expansion <=1.1.20 || 2.0.0 - 2.1.6

Severity: high

brace-expansion: Zero-step sequence causes process hang and memory exhaustion - https://github.com/advisories/GHSA-f886-m6hf-6m8v

brace-expansion: Zero-step sequence causes process hang and memory exhaustion - https://github.com/advisories/GHSA-f886-m6hf-6m8v

brace-expansion: DoS via exponential-time expansion of consecutive non-expanding {} groups - https://github.com/advisories/GHSA-3jxr-9vmj-r5cp

brace-expansion: DoS via exponential-time expansion of consecutive non-expanding {} groups - https://github.com/advisories/GHSA-3jxr-9vmj-r5cp

brace-expansion: DoS via unbounded expansion length causing an out-of-memory process crash - https://github.com/advisories/GHSA-mh99-v99m-4gvg

brace-expansion: DoS via unbounded expansion length causing an out-of-memory process crash - https://github.com/advisories/GHSA-mh99-v99m-4gvg

brace-expansion: DoS via unbounded intermediate arrays, bypassing the CVE-2026-14257 mitigation - https://github.com/advisories/GHSA-rgw5-rvv9-x895

brace-expansion: DoS via unbounded intermediate arrays, bypassing the CVE-2026-14257 mitigation - https://github.com/advisories/GHSA-rgw5-rvv9-x895

brace-expansion: Quadratic-time expansion of the `{a},b}` rewrite causes CPU denial of service - https://github.com/advisories/GHSA-q2hr-2g5m-vwhr

brace-expansion: Quadratic-time expansion of the `{a},b}` rewrite causes CPU denial of service - https://github.com/advisories/GHSA-q2hr-2g5m-vwhr

brace-expansion: DoS via uncontrolled recursion on nested brace groups causing stack exhaustion - https://github.com/advisories/GHSA-qhr7-859c-m2p7

brace-expansion: DoS via uncontrolled recursion on nested brace groups causing stack exhaustion - https://github.com/advisories/GHSA-qhr7-859c-m2p7

brace-expansion: DoS via uncontrolled recursion in parseCommaParts causing stack exhaustion - https://github.com/advisories/GHSA-6j4f-fj2g-mc7p

brace-expansion: DoS via uncontrolled recursion in parseCommaParts causing stack exhaustion - https://github.com/advisories/GHSA-6j4f-fj2g-mc7p

fix available via `npm audit fix`

node_modules/brace-expansion

node_modules/filelist/node_modules/brace-expansion

node_modules/glob/node_modules/brace-expansion

node_modules/readdir-glob/node_modules/brace-expansion

node_modules/superstatic/node_modules/brace-expansion

browserslist <=4.28.6

Severity: high

Browserslist: Unbounded memory growth (no cache eviction) via distinct query results, leading to eventual OOM - https://github.com/advisories/GHSA-c83g-rgw3-j3cx

Browserslist: Uncaught crash / prototype write via untrusted browserslist-stats.json custom stats (normalizeStats) - https://github.com/advisories/GHSA-73wf-gq98-2v4g

fix available via `npm audit fix`

node_modules/browserslist

compression <1.8.2

Severity: high

compression vulnerable to Denial of Service via memory leak on premature response close - https://github.com/advisories/GHSA-vc2v-76pw-4v95

fix available via `npm audit fix`

node_modules/compression

csv-parse <7.0.2

Severity: moderate

node-csv: Prototype replacement still reachable via columns path - https://github.com/advisories/GHSA-8cw4-87c7-c6xx

fix available via `npm audit fix --force`

Will install firebase-tools@15.35.0, which is a breaking change

node_modules/csv-parse

firebase-tools *

Depends on vulnerable versions of @google-cloud/pubsub

Depends on vulnerable versions of archiver

Depends on vulnerable versions of csv-parse

Depends on vulnerable versions of exegesis

Depends on vulnerable versions of gaxios

Depends on vulnerable versions of glob

Depends on vulnerable versions of stream-json

Depends on vulnerable versions of tar

Depends on vulnerable versions of uuid

node_modules/firebase-tools

deepmerge >=4.2.0

deepmerge mergeObject() allows prototype poisoning of returned objects - https://github.com/advisories/GHSA-gcqx-w48m-w2h4

fix available via `npm audit fix --force`

Will install next-pwa@3.1.5, which is a breaking change

node_modules/deepmerge

@rollup/plugin-node-resolve >=8.0.0

Depends on vulnerable versions of deepmerge

node_modules/@rollup/plugin-node-resolve

workbox-build >=5.0.0-alpha.0

Depends on vulnerable versions of @rollup/plugin-node-resolve

Depends on vulnerable versions of rollup-plugin-terser

node_modules/workbox-build

workbox-webpack-plugin >=6.0.0-alpha.0

Depends on vulnerable versions of workbox-build

node_modules/workbox-webpack-plugin

next-pwa >=4.0.0-beta.0

Depends on vulnerable versions of workbox-webpack-plugin

node_modules/next-pwa

dompurify <=3.4.16

Severity: high

DOMPurify allows Cross-site Scripting (XSS) - https://github.com/advisories/GHSA-vhxf-7vqr-mrjg

DOMPurify contains a Cross-site Scripting vulnerability - https://github.com/advisories/GHSA-v8jm-5vwx-cfxm

DOMPurify contains a Cross-site Scripting vulnerability - https://github.com/advisories/GHSA-v2wj-7wpq-c8vv

DOMPurify: FORBID_TAGS bypassed by function-based ADD_TAGS predicate (asymmetry with FORBID_ATTR fix) - https://github.com/advisories/GHSA-h7mw-gpvr-xq4m

DOMPurify has a SAFE_FOR_TEMPLATES bypass in RETURN_DOM mode - https://github.com/advisories/GHSA-crv5-9vww-q3g8

DOMPurify: Cross-realm IN_PLACE sanitization leaves executable markup intact via realm-bound `instanceof` checks - https://github.com/advisories/GHSA-hpcv-96wg-7vj8

DOMPurify: IN_PLACE mode preserves attributes of a clobbered root element, allowing XSS via attacker-controlled root DOM - https://github.com/advisories/GHSA-r47g-fvhr-h676

DOMPurify IN_PLACE Sanitization Bypass via Attached Shadow Root Inside <template>.content - https://github.com/advisories/GHSA-rp9w-3fw7-7cwq

DOMPurify: Permanent `ALLOWED_ATTR` pollution via `setConfig()` bypassing the hook clone-guard (incomplete fix of the 3.4.7 hook-pollution patch) - https://github.com/advisories/GHSA-cmwh-pvxp-8882

DOMPurify: Trusted Types policy survives `clearConfig()` and can poison later `RETURN_TRUSTED_TYPE` output - https://github.com/advisories/GHSA-vxr8-fq34-vvx9

DOMPurify: `IN_PLACE` mode trusts attacker-controlled `nodeName` on live non-form nodes, allowing script retention and XSS via attacker-supplied DOM objects - https://github.com/advisories/GHSA-x4vx-rjvf-j5p4

DOMPurify: Hook mutation of `data.allowedTags` / `data.allowedAttributes` permanently pollutes `DEFAULT_ALLOWED_TAGS` / `DEFAULT_ALLOWED_ATTR` - https://github.com/advisories/GHSA-76mc-f452-cxcm

DOMPurify's ADD_TAGS function form bypasses FORBID_TAGS due to short-circuit evaluation - https://github.com/advisories/GHSA-39q2-94rc-95cp

DOMPurify ADD_ATTR predicate skips URI validation - https://github.com/advisories/GHSA-cjmm-f4jc-qw8r

DOMPurify USE_PROFILES prototype pollution allows event handlers - https://github.com/advisories/GHSA-cj63-jhhr-wcxv

DOMPurify is vulnerable to mutation-XSS via Re-Contextualization - https://github.com/advisories/GHSA-h8r8-wccr-v5f2

DOMPurify: IN_PLACE hook removal leaves a detached subtree executable, causing XSS - https://github.com/advisories/GHSA-55q2-fjhq-7xh7

DOMPurify: `CUSTOM_ELEMENT_HANDLING` bypasses `afterSanitizeElements` for allowed custom elements. - https://github.com/advisories/GHSA-c2j3-45gr-mqc4

DOMPurify: IN_PLACE returns a force-removed rawtext root whose text carries attacker markup — pure HTML reparse executes - https://github.com/advisories/GHSA-6688-9rhm-gjv2

DOMPurify IN_PLACE: hook that removes a parent or sibling leaves the detached subtree's event handlers armed (incomplete fix for GHSA-p98j-92pf-mc4p) - https://github.com/advisories/GHSA-mrv2-3pqr-j5jr

DOMPurify: SMIL attributeName=href guard is skipped when PARSER_MEDIA_TYPE is application/xhtml+xml - https://github.com/advisories/GHSA-c6gr-qvv4-5v3f

fix available via `npm audit fix --force`

Will install jspdf@4.2.1, which is a breaking change

node_modules/dompurify

jspdf <=4.2.0

Depends on vulnerable versions of dompurify

node_modules/jspdf

extract-zip *

Severity: high

extract-zip unvalidated symlink path traversal - https://github.com/advisories/GHSA-jmr9-qjv8-65gv

extract-zip allows arbitrary file writes through symlink archive entries - https://github.com/advisories/GHSA-7pqw-9j4j-h8q3

fix available via `npm audit fix`

node_modules/extract-zip

genkit-cli 0.9.0-dev.1 - 1.44.1

Depends on vulnerable versions of @genkit-ai/telemetry-server

Depends on vulnerable versions of @genkit-ai/tools-common

Depends on vulnerable versions of extract-zip

node_modules/genkit-cli

fast-uri 3.0.0 - 3.1.8

Severity: high

fast-uri vulnerable to host confusion via literal backslash authority delimiter - https://github.com/advisories/GHSA-v2hh-gcrm-f6hx

fast-uri vulnerable to host confusion via backslash authority introducer - https://github.com/advisories/GHSA-7p8r-x3mc-p8w7

fast-uri vulnerable to path traversal via percent-encoded dot segments - https://github.com/advisories/GHSA-q3j6-qgpj-74h6

fast-uri vulnerable to host confusion via percent-encoded authority delimiters - https://github.com/advisories/GHSA-v39h-62p7-jpjc

fast-uri vulnerable to server-side request forgery via malformed IPv6 normalization - https://github.com/advisories/GHSA-f65p-4m7j-42xc

fast-uri vulnerable to host confusion via percent-encoded scheme normalization - https://github.com/advisories/GHSA-jqff-g426-hqxp

fast-uri vulnerable to host confusion via failed IDN canonicalization - https://github.com/advisories/GHSA-4c8g-83qw-93j6

fast-uri vulnerable to authority injection via an unvalidated port in serialize - https://github.com/advisories/GHSA-qw65-cvwx-89v3

fast-uri vulnerable to inconsistent host case normalization via percent-encoded octets - https://github.com/advisories/GHSA-hrr3-gc8f-f4qj

fast-uri vulnerable to URI scheme spoofing via percent-encoded scheme decoding - https://github.com/advisories/GHSA-w74x-v6f9-j3xg

fast-uri vulnerable to improper path equivalence in relative reference normalization - https://github.com/advisories/GHSA-xhq7-xmqj-769h

fast-uri vulnerable to scheme injection via an unescaped first-segment colon in suffix references - https://github.com/advisories/GHSA-333x-w4r6-6crp

fix available via `npm audit fix`

node_modules/fast-uri

fast-xml-parser <=5.6.0

Severity: critical

fast-xml-parser has an entity encoding bypass via regex injection in DOCTYPE entity names - https://github.com/advisories/GHSA-m7jm-9gc2-mpf2

fast-xml-parser affected by DoS through entity expansion in DOCTYPE (no expansion limit) - https://github.com/advisories/GHSA-jmr7-xgp7-cmfj

fast-xml-parser has stack overflow in XMLBuilder with preserveOrder - https://github.com/advisories/GHSA-fj3w-jwp8-x2g3

fast-xml-parser affected by numeric entity expansion bypassing all entity expansion limits (incomplete fix for CVE-2026-26278) - https://github.com/advisories/GHSA-8gc5-j5rx-235r

Entity Expansion Limits Bypassed When Set to Zero Due to JavaScript Falsy Evaluation in fast-xml-parser - https://github.com/advisories/GHSA-jp2q-39xq-3w4g

fast-xml-parser XMLBuilder: XML Comment and CDATA Injection via Unescaped Delimiters - https://github.com/advisories/GHSA-gh4j-gqv2-49f6

fix available via `npm audit fix`

node_modules/fast-xml-parser

@google-cloud/storage 2.2.0 - 2.5.0 || 5.19.0 - 8.0.0

Depends on vulnerable versions of fast-xml-parser

Depends on vulnerable versions of retry-request

Depends on vulnerable versions of teeny-request

Depends on vulnerable versions of uuid

node_modules/@google-cloud/storage

fflate 0.8.0 - 0.8.2

Severity: moderate

fflate unzipSync can enter an infinite loop when parsing malformed ZIP64 archives - https://github.com/advisories/GHSA-px8p-9vwx-vf98

fix available via `npm audit fix`

node_modules/fflate

follow-redirects <=1.15.11

Severity: moderate

follow-redirects leaks Custom Authentication Headers to Cross-Domain Redirect Targets - https://github.com/advisories/GHSA-r4q5-vmmm-2653

fix available via `npm audit fix`

node_modules/follow-redirects

form-data >=4.0.0 <4.0.6 || <2.5.6

Severity: high

form-data: CRLF injection in form-data via unescaped multipart field names and filenames - https://github.com/advisories/GHSA-hmw2-7cc7-3qxx

form-data: CRLF injection in form-data via unescaped multipart field names and filenames - https://github.com/advisories/GHSA-hmw2-7cc7-3qxx

fix available via `npm audit fix`

node_modules/@types/request/node_modules/form-data

node_modules/form-data

glob 9.0.0 - 14.0.1

Severity: moderate

Glob: AbortSignal cancellation bypass allows post-timeout filesystem traversal - https://github.com/advisories/GHSA-3g3m-2fjr-6pw4

fix available via `npm audit fix --force`

Will install firebase-tools@15.35.0, which is a breaking change

node_modules/glob

node_modules/rimraf/node_modules/glob

archiver-utils >=5.0.1

Depends on vulnerable versions of glob

node_modules/archiver-utils

archiver 7.0.0 - 7.0.1

Depends on vulnerable versions of archiver-utils

Depends on vulnerable versions of zip-stream

node_modules/archiver

zip-stream 6.0.0 - 6.0.1

Depends on vulnerable versions of archiver-utils

node_modules/zip-stream

cacache >=17.0.5

Depends on vulnerable versions of glob

node_modules/cacache

make-fetch-happen >=13.0.0

Depends on vulnerable versions of cacache

node_modules/make-fetch-happen

node-gyp 10.0.0 - 12.2.0

Depends on vulnerable versions of make-fetch-happen

node_modules/node-gyp

re2 <=1.26.0

Depends on vulnerable versions of node-gyp

node_modules/re2

exegesis >=4.1.2

Depends on vulnerable versions of glob

node_modules/exegesis

rimraf 4.2.0 - 6.1.3

Depends on vulnerable versions of glob

node_modules/@google-cloud/cloud-sql-connector/node_modules/rimraf

node_modules/@google-cloud/modelarmor/node_modules/rimraf

node_modules/googleapis-common/node_modules/rimraf

node_modules/rimraf

gaxios 6.4.0 - 6.7.1 || 7.1.3

Depends on vulnerable versions of rimraf

Depends on vulnerable versions of uuid

node_modules/@google-cloud/cloud-sql-connector/node_modules/gaxios

node_modules/@google-cloud/modelarmor/node_modules/gaxios

node_modules/gaxios

node_modules/googleapis-common/node_modules/gaxios

google-gax 4.0.5-experimental - 4.6.1 || 5.0.5 - 5.0.8

Depends on vulnerable versions of retry-request

Depends on vulnerable versions of rimraf

Depends on vulnerable versions of uuid

node_modules/@google-cloud/modelarmor/node_modules/google-gax

node_modules/google-gax

@google-cloud/firestore 7.5.0-pre.0 || 7.6.0 - 7.11.6

Depends on vulnerable versions of google-gax

node_modules/@google-cloud/firestore

firebase-admin 10.2.0 - 13.10.0

Depends on vulnerable versions of @google-cloud/firestore

Depends on vulnerable versions of uuid

node_modules/firebase-admin

@google-cloud/pubsub 2.11.1-pre || 4.3.0 - 4.11.0

Depends on vulnerable versions of google-gax

node_modules/@google-cloud/pubsub

handlebars 3.0.0 - 4.7.9

Severity: critical

Handlebars.js has JavaScript Injection via AST Type Confusion by tampering @partial-block - https://github.com/advisories/GHSA-3mfm-83xf-c92r

Handlebars.js has JavaScript Injection via AST Type Confusion - https://github.com/advisories/GHSA-2w6w-674q-4c4q

Handlebars.js has Prototype Pollution Leading to XSS through Partial Template Injection - https://github.com/advisories/GHSA-2qvq-rjwj-gvw9

Handlebars.js has a Prototype Method Access Control Gap via Missing __lookupSetter__ Blocklist Entry - https://github.com/advisories/GHSA-7rx3-28cr-v5wh

Handlebars.js has a Property Access Validation Bypass in container.lookup - https://github.com/advisories/GHSA-442j-39wm-28r2

Handlebars.js has JavaScript Injection via AST Type Confusion when passing an object as dynamic partial - https://github.com/advisories/GHSA-xhpv-hc6g-r9c6

Handlebars.js has Denial of Service via Malformed Decorator Syntax in Template Compilation - https://github.com/advisories/GHSA-9cx6-37pm-9jff

Handlebars.js has JavaScript Injection in CLI Precompiler via Unescaped Names and Options - https://github.com/advisories/GHSA-xjpj-3mr7-gcpf

Handlebars: JavaScript Injection via Unsafe Inline Embedding of Precompiled Templates - https://github.com/advisories/GHSA-xw65-4hp5-5hc7

Handlebars: JavaScript Injection via AST Type Confusion in compile (bypass of CVE-2026-33937) - https://github.com/advisories/GHSA-8r5x-fm3f-whwj

Handlebars: JavaScript Injection via Own Property Check Bypass - https://github.com/advisories/GHSA-p8wg-vrv2-v86f

fix available via `npm audit fix`

node_modules/handlebars

ip-address <=10.7.3

Severity: high

ip-address has XSS in Address6 HTML-emitting methods - https://github.com/advisories/GHSA-v2v4-37r5-5v8g

ip-address: Address4 decodes leading-zero octets as decimal while resolvers decode them as octal, allowing SSRF and trust-boundary bypass - https://github.com/advisories/GHSA-mwp4-54f8-5fhr

ip-address: Address6.isLinkLocal() recognizes fe80::/64 rather than fe80::/10, allowing SSRF and trust-boundary bypass to on-link hosts - https://github.com/advisories/GHSA-rpw4-54j3-4h4q

ip-address: isInSubnet() and isHostInSubnet() compare addresses of different families as if they shared an address space, allowing an allowlist check to admit an address outside its range - https://github.com/advisories/GHSA-j6r3-76f7-8jcv

ip-address: Address6 builds a parse diagnostic proportional to the input with no length bound, allowing a single long string to stall or crash the process - https://github.com/advisories/GHSA-h3mg-xc3c-68pw

ip-address: Address6 matches a zone identifier in quadratic time ahead of its length limit, allowing a single long string to stall the process - https://github.com/advisories/GHSA-rxp7-6hxx-x8q5

fix available via `npm audit fix`

node_modules/ip-address

js-yaml <=3.15.1 || 4.0.0 - 4.3.1

Severity: high

JS-YAML: Quadratic-complexity DoS in merge key handling via repeated aliases - https://github.com/advisories/GHSA-h67p-54hq-rp68

JS-YAML: Quadratic-complexity DoS in merge key handling via repeated aliases - https://github.com/advisories/GHSA-h67p-54hq-rp68

js-yaml: YAML merge-key chains can force quadratic CPU consumption - https://github.com/advisories/GHSA-52cp-r559-cp3m

js-yaml: YAML merge-key chains can force quadratic CPU consumption - https://github.com/advisories/GHSA-52cp-r559-cp3m

JS-YAML: Quadratic CPU consumption in !!omap resolution (3.x and 4.x) — CVE-2026-59870 fix not backported - https://github.com/advisories/GHSA-5p4m-2wfm-xmqj

JS-YAML: Quadratic CPU consumption in !!omap resolution (3.x and 4.x) — CVE-2026-59870 fix not backported - https://github.com/advisories/GHSA-5p4m-2wfm-xmqj

js-yaml: maxTotalMergeKeys does not limit CPU use for empty merge sources - https://github.com/advisories/GHSA-2883-xcg3-v3hh

js-yaml: maxTotalMergeKeys does not limit CPU use for empty merge sources - https://github.com/advisories/GHSA-2883-xcg3-v3hh

fix available via `npm audit fix`

node_modules/@apidevtools/json-schema-ref-parser/node_modules/js-yaml

node_modules/@genkit-ai/tools-common/node_modules/js-yaml

node_modules/js-yaml

json-2-csv 3.15.0 - 5.5.10

Severity: moderate

json-2-csv vulnerable to CSV Injection via the preventCsvInjection optio - https://github.com/advisories/GHSA-g27c-q7cp-mhx6

fix available via `npm audit fix`

node_modules/json-2-csv

linkify-it <=5.0.1

Severity: high

LinkifyIt#match scan loop has quadratic algorithmic complexity - https://github.com/advisories/GHSA-22p9-wv53-3rq4

linkify-it: Quadratic-complexity DoS via the `mailto:` validator scan-loop on attacker text - https://github.com/advisories/GHSA-v245-v573-v5vm

fix available via `npm audit fix`

node_modules/linkify-it

lodash 4.0.0 - 4.17.23

Severity: high

lodash vulnerable to Code Injection via `_.template` imports key names - https://github.com/advisories/GHSA-r5fr-rjxr-66jc

Lodash has Prototype Pollution Vulnerability in `_.unset`, `_.omit`, and `_.pullAt` functions - https://github.com/advisories/GHSA-xxjr-mmjv-4gpg

fix available via `npm audit fix`

node_modules/lodash

markdown-it <=14.3.2

Severity: high

markdown-it: Quadratic complexity DoS in smartquotes rule via replaceAt string operations - https://github.com/advisories/GHSA-6v5v-wf23-fmfq

markdown-it: Quadratic complexity in smartquotes with unmatched closing quotes - https://github.com/advisories/GHSA-r7fv-28h4-cvq7

markdown-it: Quadratic-time denial of service in inline HTML parsing with html enabled - https://github.com/advisories/GHSA-vfgh-jcmw-g37q

markdown-it: Quadratic-time rendering of a single multi-line link reference definition with default options (regression since 14.0) - https://github.com/advisories/GHSA-gfr2-rv44-r23c

markdown-it linkify: true has two quadratic paths, so a few hundred KB of markdown blocks the event loop for tens of seconds - https://github.com/advisories/GHSA-253c-mchw-3w2r

fix available via `npm audit fix`

node_modules/markdown-it

minimatch <=3.1.3 || 5.0.0 - 5.1.7 || 6.0.0 - 6.2.1 || 7.0.0 - 11.0.0

Severity: high

minimatch has a ReDoS via repeated wildcards with non-matching literal in pattern - https://github.com/advisories/GHSA-3ppc-4f35-3m26

minimatch has a ReDoS via repeated wildcards with non-matching literal in pattern - https://github.com/advisories/GHSA-3ppc-4f35-3m26

minimatch has a ReDoS via repeated wildcards with non-matching literal in pattern - https://github.com/advisories/GHSA-3ppc-4f35-3m26

minimatch has a ReDoS via repeated wildcards with non-matching literal in pattern - https://github.com/advisories/GHSA-3ppc-4f35-3m26

minimatch has a ReDoS via repeated wildcards with non-matching literal in pattern - https://github.com/advisories/GHSA-3ppc-4f35-3m26

minimatch has ReDoS: matchOne() combinatorial backtracking via multiple non-adjacent GLOBSTAR segments - https://github.com/advisories/GHSA-7r86-cg39-jmmj

minimatch has ReDoS: matchOne() combinatorial backtracking via multiple non-adjacent GLOBSTAR segments - https://github.com/advisories/GHSA-7r86-cg39-jmmj

minimatch has ReDoS: matchOne() combinatorial backtracking via multiple non-adjacent GLOBSTAR segments - https://github.com/advisories/GHSA-7r86-cg39-jmmj

minimatch has ReDoS: matchOne() combinatorial backtracking via multiple non-adjacent GLOBSTAR segments - https://github.com/advisories/GHSA-7r86-cg39-jmmj

minimatch has ReDoS: matchOne() combinatorial backtracking via multiple non-adjacent GLOBSTAR segments - https://github.com/advisories/GHSA-7r86-cg39-jmmj

minimatch ReDoS: nested *() extglobs generate catastrophically backtracking regular expressions - https://github.com/advisories/GHSA-23c5-xmqv-rm74

minimatch ReDoS: nested *() extglobs generate catastrophically backtracking regular expressions - https://github.com/advisories/GHSA-23c5-xmqv-rm74

minimatch ReDoS: nested *() extglobs generate catastrophically backtracking regular expressions - https://github.com/advisories/GHSA-23c5-xmqv-rm74

minimatch ReDoS: nested *() extglobs generate catastrophically backtracking regular expressions - https://github.com/advisories/GHSA-23c5-xmqv-rm74

minimatch ReDoS: nested *() extglobs generate catastrophically backtracking regular expressions - https://github.com/advisories/GHSA-23c5-xmqv-rm74

minimatch has potential denial of service via globparts amplification - https://github.com/advisories/GHSA-g3hv-75wg-m249

fix available via `npm audit fix`

node_modules/filelist/node_modules/minimatch

node_modules/glob/node_modules/minimatch

node_modules/minimatch

node_modules/readdir-glob/node_modules/minimatch

node_modules/rimraf/node_modules/minimatch

node_modules/superstatic/node_modules/minimatch

morgan <=1.12.0

Severity: moderate

morgan vulnerable to Log Forging via unneutralized control characters in :remote-user - https://github.com/advisories/GHSA-4vj7-5mj6-jm8m

morgan vulnerable to Log Forging via unescaped Unicode line separators - https://github.com/advisories/GHSA-jxfw-x594-9x9m

morgan vulnerable to Log Injection via unescaped double quote in quoted log fields - https://github.com/advisories/GHSA-9f6g-j8ch-79g4

fix available via `npm audit fix`

node_modules/morgan

nanoid <=3.3.17

Severity: high

nanoid: non-secure generators can loop indefinitely with negative size - https://github.com/advisories/GHSA-28wg-ghj8-5hjv

nanoid: custom generators can loop indefinitely when size is zero - https://github.com/advisories/GHSA-2v37-7h3g-55p8

nanoid: Integer Overflow or Wraparound - https://github.com/advisories/GHSA-xwg4-73v4-xw9w

fix available via `npm audit fix`

node_modules/nanoid

next 9.3.4-canary.0 - 16.4.0

Severity: critical

Next.js self-hosted applications vulnerable to DoS via Image Optimizer remotePatterns configuration - https://github.com/advisories/GHSA-9g9p-9gw9-jx7f

Next.js HTTP request deserialization can lead to DoS when using insecure React Server Components - https://github.com/advisories/GHSA-h25m-26qc-wcjf

Next.js: HTTP request smuggling in rewrites - https://github.com/advisories/GHSA-ggv3-7p47-pfv8

Next.js: Unbounded next/image disk cache growth can exhaust storage - https://github.com/advisories/GHSA-3x4c-7xq6-9pq8

Next.js: Unbounded postponed resume buffering can lead to DoS - https://github.com/advisories/GHSA-h27x-g6w4-24gq

Next.js: null origin can bypass Server Actions CSRF checks - https://github.com/advisories/GHSA-mq59-m269-xvcx

Next.js: null origin can bypass dev HMR websocket CSRF checks - https://github.com/advisories/GHSA-jcc7-9wpm-mj36

Next.js has Unbounded Memory Consumption via PPR Resume Endpoint - https://github.com/advisories/GHSA-5f7q-jpqc-wp7h

Next.js has a Denial of Service with Server Components - https://github.com/advisories/GHSA-q4gf-8mx6-v5v3

Next.js Vulnerable to Denial of Service with Server Components - https://github.com/advisories/GHSA-8h8q-6873-q5fj

Next.js's Middleware / Proxy redirects can be cache-poisoned - https://github.com/advisories/GHSA-3g8h-86w9-wvmq

Next.js vulnerable to cross-site scripting in App Router applications using CSP nonces - https://github.com/advisories/GHSA-ffhc-5mcf-pf4q

Next.js vulnerable to cache poisoning via collisions in React Server Component cache-busting - https://github.com/advisories/GHSA-vfv6-92ff-j949

Next.js has cross-site scripting in beforeInteractive scripts with untrusted input - https://github.com/advisories/GHSA-gx5p-jg67-6x7h

Next.js vulnerable to Denial of Service via connection exhaustion in applications using Cache Components - https://github.com/advisories/GHSA-mg66-mrh9-m8jx

Next.js has a Denial of Service in the Image Optimization API - https://github.com/advisories/GHSA-h64f-5h5j-jqjh

Next.js vulnerable to server-side request forgery in applications using WebSocket upgrades - https://github.com/advisories/GHSA-c4j6-fc7j-m34r

Next.js has a Middleware / Proxy bypass through dynamic route parameter injection - https://github.com/advisories/GHSA-492v-c6pp-mqqv

Next.js vulnerable to cache poisoning in React Server Component responses - https://github.com/advisories/GHSA-wfc6-r584-vfw7

Next.js has a Middleware / Proxy bypass in App Router applications via segment-prefetch routes - https://github.com/advisories/GHSA-267c-6grr-h53f

Next.js has a Middleware / Proxy bypass in Pages Router applications using i18n - https://github.com/advisories/GHSA-36qx-fr4f-26g5

Next.js: Middleware / Proxy bypass in App Router applications using Turbopack and single locale - https://github.com/advisories/GHSA-6gpp-xcg3-4w24

Next.js: Denial of Service in App Router using Server Actions - https://github.com/advisories/GHSA-m99w-x7hq-7vfj

Next.js: Server-Side Request Forgery in Server Actions on custom servers - https://github.com/advisories/GHSA-89xv-2m56-2m9x

Next.js: Cache confusion of response bodies for requests with bodies - https://github.com/advisories/GHSA-68g3-v927-f742

Next.js: Cache confusion of response bodies for requests with bodies containing invalid UTF-8 byte sequences - https://github.com/advisories/GHSA-4633-3j49-mh5q

Next.js: Unbounded Server Action payload in Edge runtime - https://github.com/advisories/GHSA-4c39-4ccg-62r3

Next.js: Server-Side Request Forgery in rewrites via attacker-controlled destination hostname - https://github.com/advisories/GHSA-p9j2-gv94-2wf4

Next.js: Denial of Service in the Image Optimization API using SVGs - https://github.com/advisories/GHSA-q8wf-6r8g-63ch

Next.js: Unauthenticated disclosure of internal Server Function endpoints - https://github.com/advisories/GHSA-955p-x3mx-jcvp

Next.js: Unauthenticated Remote Code Execution on windows-hosted servers - https://github.com/advisories/GHSA-p293-qw3h-jr36

Next.js: Unauthenticated Remote Code Execution in Image Optimization API when AVIF files are used - https://github.com/advisories/GHSA-2xp9-vwfh-vxw4

Next.js has cache poisoning of SSG and ISR pages in self-hosted applications - https://github.com/advisories/GHSA-4jqv-mc3x-m676

Next.js has information disclosure in development server's Model Context Protocol endpoint - https://github.com/advisories/GHSA-39w2-rjm5-chcv

Next.js has information disclosure in App Router metadata image routes via dynamicParams bypass - https://github.com/advisories/GHSA-f87g-xv8r-7p7x

Next.js has cache poisoning in SSG/ISR rendering that leads to cross-user content substitution and persistent denial of service - https://github.com/advisories/GHSA-mcj8-r9mp-w47p

Next.js has Server-Side Request Forgery in Image Optimization - https://github.com/advisories/GHSA-cjq9-62q9-8jv4

Next.js: Unauthenticated Remote Code Execution in Image Optimization API when SVG files are used - https://github.com/advisories/GHSA-2464-fhr4-w9xw

Next.js: Denial of Service in App Router using Server Actions - https://github.com/advisories/GHSA-p3m5-59mp-jv5r

Next.js: Unauthenticated Remote Code Execution in `use cache` functions returning typed arrays - https://github.com/advisories/GHSA-673q-mjm6-r5xr

Next.js has a Middleware / Proxy bypass in App Router applications via segment-prefetch routes - Incomplete Fix Follow-Up - https://github.com/advisories/GHSA-26hh-7cqf-hhc6

Depends on vulnerable versions of postcss

Depends on vulnerable versions of sharp

fix available via `npm audit fix`

node_modules/next

node-forge <=1.4.0

Severity: high

node-forge RSA PKCS#1 v1.5 signature verification accepts extra nested DigestAlgorithm elements - https://github.com/advisories/GHSA-86w9-cpqp-85rv

Forge: ASN.1 OID first arc truncation in asn1.oidToDer - https://github.com/advisories/GHSA-4642-5mcj-2rqw

Forge: Prototype Pollution in forge.http cookie handling via a malicious Set-Cookie - https://github.com/advisories/GHSA-6wvx-3r32-xmcg

Forge: TLS client crash when the server sends no certificate - https://github.com/advisories/GHSA-525v-9gp9-w22h

Forge: Regular expression denial of service in PEM decoding (pem.decode) - https://github.com/advisories/GHSA-7wch-p9px-956x

Forge: Denial of Service via infinite loop in BigInteger.modInverse() with negative input (incomplete fix of CVE-2026-33891) - https://github.com/advisories/GHSA-h6cr-wjv9-3cpp

Forge: verifyCertificateChain() removes trusted CA certificates with the same subject from the CA store - https://github.com/advisories/GHSA-4487-j8r4-4g2f

Forge: AES-GCM authentication bypass via unvalidated tagLength option - https://github.com/advisories/GHSA-5cwg-6vw7-rj6p

Forge: PKCS#12 MAC forgery and constant-key PBE via zero iteration count - https://github.com/advisories/GHSA-jc66-7q78-782g

Forge: Denial of service in TLS record processing via a record interleaved with a fragmented handshake message - https://github.com/advisories/GHSA-8hrf-8g6f-7xwp

Forge: Denial of service in TLS record processing via call stack exhaustion - https://github.com/advisories/GHSA-hqq3-7jhf-c5jx

Forge: X.509 basicConstraints bypass in verifyCertificateChain() via deprecated extension OIDs 2.5.29.10 and 2.5.29.13 - https://github.com/advisories/GHSA-5x38-2vff-x55p

fix available via `npm audit fix`

node_modules/node-forge

path-to-regexp <=0.1.12 || 8.0.0 - 8.3.0

Severity: high

path-to-regexp vulnerable to Regular Expression Denial of Service via multiple route parameters - https://github.com/advisories/GHSA-37ch-88jc-xwx2

path-to-regexp vulnerable to Denial of Service via sequential optional groups - https://github.com/advisories/GHSA-j3q9-mxjg-w52f

path-to-regexp vulnerable to Regular Expression Denial of Service via multiple wildcards - https://github.com/advisories/GHSA-27v5-c462-wpq7

fix available via `npm audit fix`

node_modules/path-to-regexp

node_modules/router/node_modules/path-to-regexp

picomatch <=2.3.1 || 4.0.0 - 4.0.3

Severity: high

Picomatch: Method Injection in POSIX Character Classes causes incorrect Glob Matching - https://github.com/advisories/GHSA-3v7f-55p6-f55p

Picomatch: Method Injection in POSIX Character Classes causes incorrect Glob Matching - https://github.com/advisories/GHSA-3v7f-55p6-f55p

Picomatch has a ReDoS vulnerability via extglob quantifiers - https://github.com/advisories/GHSA-c2c7-rcm5-vvqj

Picomatch has a ReDoS vulnerability via extglob quantifiers - https://github.com/advisories/GHSA-c2c7-rcm5-vvqj

fix available via `npm audit fix`

node_modules/picomatch

node_modules/tinyglobby/node_modules/picomatch

postcss <=8.5.22

Severity: high

PostCSS has XSS via Unescaped </style> in its CSS Stringify Output - https://github.com/advisories/GHSA-qx2v-qp2m-jg93

PostCSS: Arbitrary file read and information disclosure via attacker-controlled sourceMappingURL in CSS comments - https://github.com/advisories/GHSA-6g55-p6wh-862q

PostCSS: incomplete fix of GHSA-6g55-p6wh-862q — attacker-controlled sourceMappingURL reads arbitrary .map files when `from` is unset - https://github.com/advisories/GHSA-fxqj-rqcc-2cmp

PostCSS: Path Traversal in Previous Source Map Auto-Loading (sourceMappingURL) leads to Arbitrary .map File Disclosure - https://github.com/advisories/GHSA-r28c-9q8g-f849

fix available via `npm audit fix`

node_modules/next/node_modules/postcss

node_modules/postcss

postcss-selector-parser <=6.1.4

Severity: moderate

postcss-selector-parser allows denial of service through uncontrolled AST recursion - https://github.com/advisories/GHSA-w9m9-85wc-3x92

PostCSS: Quadratic complexity in flat selector parsing allows CPU exhaustion - https://github.com/advisories/GHSA-rj75-hqrm-r3gf

fix available via `npm audit fix`

node_modules/postcss-selector-parser

prosemirror-view <1.42.3

Severity: high

ProseMirror has a XSS vulnerability in prosemirror-view's paste handling - https://github.com/advisories/GHSA-c8x8-7fp4-3x9w

fix available via `npm audit fix`

node_modules/prosemirror-view

protobufjs <=7.6.4

Severity: critical

protobuf.js: Code injection through bytes field defaults in generated toObject code - https://github.com/advisories/GHSA-66ff-xgx4-vchm

protobuf.js: Denial of service from crafted field names in generated code - https://github.com/advisories/GHSA-2pr8-phx7-x9h3

protobuf.js: Prototype injection in generated message constructors - https://github.com/advisories/GHSA-fx83-v9x8-x52w

protobuf.js: Code generation gadget after prototype pollution - https://github.com/advisories/GHSA-75px-5xx7-5xc7

protobuf.js: Process-wide denial of service through unsafe option paths - https://github.com/advisories/GHSA-jvwf-75h9-cwgg

protobuf.js: Denial of service through unbounded protobuf recursion - https://github.com/advisories/GHSA-685m-2w69-288q

protobufjs has overlong UTF-8 decoding - https://github.com/advisories/GHSA-q6x5-8v7m-xcrf

protobufjs: Denial of Service via unbounded recursive JSON descriptor expansion - https://github.com/advisories/GHSA-jggg-4jg4-v7c6

protobufjs: Denial of service through unbounded Any expansion during JSON conversion - https://github.com/advisories/GHSA-wcpc-wj8m-hjx6

protobufjs : Schema-derived names can shadow runtime-significant properties - https://github.com/advisories/GHSA-f38q-mgvj-vph7

protobufjs: Denial of Service via infinite loop in .proto option parsing - https://github.com/advisories/GHSA-j3f2-48v5-ccww

protobufjs has an arbitrary code execution issue - https://github.com/advisories/GHSA-xq3m-2v4x-88gg

fix available via `npm audit fix`

node_modules/protobufjs

proxy-addr 1.1.0 - 2.0.7

Severity: critical

proxy-addr vulnerable to IP spoofing via IPv4-mapped IPv6 trust subnet - https://github.com/advisories/GHSA-jqcg-44mw-7w3h

fix available via `npm audit fix`

node_modules/proxy-addr

qs <=6.16.0

Severity: moderate

qs's arrayLimit bypass in comma parsing allows denial of service - https://github.com/advisories/GHSA-w7fw-mjwx-w883

qs's arrayLimit bypass in its bracket notation allows DoS via memory exhaustion - https://github.com/advisories/GHSA-6rw7-vpxm-498p

qs has a remotely triggerable DoS: qs.stringify crashes with TypeError on null/undefined entries in comma-format arrays when encodeValuesOnly is set - https://github.com/advisories/GHSA-q8mj-m7cp-5q26

qs: Denial of Service via Attacker Controlled isBuffer - https://github.com/advisories/GHSA-4mjr-xmp4-gh2g

qs : qs.stringify with arrayFormat 'comma' throws an uncaught TypeError on array elements carrying a non-callable own toString (DoS) - https://github.com/advisories/GHSA-6pq8-jhm2-2vcw

fix available via `npm audit fix`

node_modules/qs

express 4.10.0 - 4.22.2 || 5.0.0-alpha.1 - 5.0.1

Depends on vulnerable versions of qs

node_modules/express

rollup <2.80.0

Severity: high

Rollup 4 has Arbitrary File Write via Path Traversal - https://github.com/advisories/GHSA-mw96-cpmx-2vgc

fix available via `npm audit fix`

node_modules/rollup

serialize-javascript <=7.1.2

Severity: high

Serialize JavaScript is Vulnerable to RCE via RegExp.flags and Date.prototype.toISOString() - https://github.com/advisories/GHSA-5c6j-r48x-rmvq

Serialize JavaScript has CPU Exhaustion Denial of Service via crafted array-like objects - https://github.com/advisories/GHSA-qj8w-gfj5-8c6v

Serialize JavaScript: Cross-site scripting (XSS) via unescaped </script at the end of a serialized function body - https://github.com/advisories/GHSA-m5mm-p8h7-m29v

fix available via `npm audit fix --force`

Will install next-pwa@3.1.5, which is a breaking change

node_modules/rollup-plugin-terser/node_modules/serialize-javascript

node_modules/serialize-javascript

rollup-plugin-terser 3.0.0 || >=4.0.4

Depends on vulnerable versions of serialize-javascript

node_modules/rollup-plugin-terser

terser-webpack-plugin 4.2.1 - 5.3.16

Depends on vulnerable versions of serialize-javascript

node_modules/terser-webpack-plugin

sharp <=0.35.5-rc.1

Severity: high

sharp inherited vulnerabilities in libvips: CVE-2026-33327, CVE-2026-33328, CVE-2026-35590, CVE-2026-35591 - https://github.com/advisories/GHSA-f88m-g3jw-g9cj

sharp: Vulnerabilities in libheif: GHSA-g89c-p67h-r497 and GHSA-2jg2-4ch7-h545 - https://github.com/advisories/GHSA-rgj7-g3m4-5g8c

sharp : Vulnerability in librsvg dependency CVE-2026-96889 - https://github.com/advisories/GHSA-wq5f-xc86-pv6w

fix available via `npm audit fix --force`

Will install sharp@0.35.5, which is a breaking change

node_modules/sharp

source-map-js 1.0.0 - 1.2.1

Severity: high

source-map-js allows event-loop denial of service through indexed source-map section offsets - https://github.com/advisories/GHSA-68fv-2mgg-jv7q

fix available via `npm audit fix`

node_modules/source-map-js

stream-json <=3.5.0

Severity: moderate

stream-json: pick/ignore/filter/replace filters are O(depth^2) on nested input — small crafted JSON blocks the event loop for seconds→minutes (DoS) - https://github.com/advisories/GHSA-528h-pc64-c93x

stream-json: JSONC parser and verifier re-scan the whole accumulated comment on every input chunk - https://github.com/advisories/GHSA-hqr4-qq8f-hg3x

stream-json has a prototype pollution issue: Assembler writes this.current[this.key] on plain objects - https://github.com/advisories/GHSA-mjw6-4jj6-33hc

fix available via `npm audit fix`

node_modules/stream-json

tar <=7.5.20

Severity: critical

node-tar Vulnerable to Arbitrary File Creation/Overwrite via Hardlink Path Traversal - https://github.com/advisories/GHSA-34x7-hfp2-rc4v

node-tar is Vulnerable to Arbitrary File Overwrite and Symlink Poisoning via Insufficient Path Sanitization - https://github.com/advisories/GHSA-8qq5-rm4j-mr97

Arbitrary File Read/Write via Hardlink Target Escape Through Symlink Chain in node-tar Extraction - https://github.com/advisories/GHSA-83g3-92jg-28cx

tar has Hardlink Path Traversal via Drive-Relative Linkpath - https://github.com/advisories/GHSA-qffp-2rhf-9h96

node-tar Symlink Path Traversal via Drive-Relative Linkpath - https://github.com/advisories/GHSA-9ppj-qmqm-q256

Race Condition in node-tar Path Reservations via Unicode Ligature Collisions on macOS APFS - https://github.com/advisories/GHSA-r6q2-hw4h-h46w

node-tar applies PAX size override to intermediary GNU long-name/long-link headers, causing tar parser interpretation differential (file smuggling) - https://github.com/advisories/GHSA-vmf3-w455-68vh

node-tar: Process crash via PAX numeric path type confusion - https://github.com/advisories/GHSA-w8wr-v893-vjvp

node-tar: Decompression/parse DoS via unlimited input - https://github.com/advisories/GHSA-23hp-3jrh-7fpw

node-tar: Negative tar entry size causes infinite loop in archive replace - https://github.com/advisories/GHSA-8x88-c5mf-7j5w

node-tar: Uncaught Exception DoS via NUL byte in PAX path/linkpath records - https://github.com/advisories/GHSA-gvwx-54wh-qm9j

node-tar: Uncontrolled recursion in mapHas/filesFilter allows uncatchable stack-overflow DoS via crafted long-path tar with member selection - https://github.com/advisories/GHSA-r292-9mhp-454m

fix available via `npm audit fix --force`

Will install firebase-tools@15.35.0, which is a breaking change

node_modules/cacache/node_modules/tar

node_modules/node-gyp/node_modules/tar

node_modules/tar

@capacitor/cli 0.0.10 - 1.1.1 || 3.0.0-alpha.0 - 7.4.5 || 8.0.0-alpha.1 - 8.0.2-nightly-20260127T151145.0

Depends on vulnerable versions of tar

node_modules/@capacitor/cli

tmp <0.2.6

Severity: high

tmp has Path Traversal via unsanitized prefix/postfix that enables directory escape - https://github.com/advisories/GHSA-ph9p-34f9-6g65

fix available via `npm audit fix`

node_modules/tmp

undici <=6.29.0

Severity: high

Use of Insufficiently Random Values in undici - https://github.com/advisories/GHSA-c76h-2ccp-4975

Undici has an unbounded decompression chain in HTTP responses on Node.js Fetch API via Content-Encoding leads to resource exhaustion - https://github.com/advisories/GHSA-g9mf-h72j-4rw9

undici Denial of Service attack via bad certificate data - https://github.com/advisories/GHSA-cxrh-j4jr-qwg3

Undici: Malicious WebSocket 64-bit length overflows parser and crashes the client - https://github.com/advisories/GHSA-f269-vfmq-vjvj

Undici has an HTTP Request/Response Smuggling issue - https://github.com/advisories/GHSA-2mjp-6q6p-2qxm

Undici has Unbounded Memory Consumption in WebSocket permessage-deflate Decompression - https://github.com/advisories/GHSA-vrm6-8vpv-qv8q

Undici has Unhandled Exception in WebSocket Client Due to Invalid server_max_window_bits Validation - https://github.com/advisories/GHSA-v9p9-hfj2-hcw8

Undici has CRLF Injection in undici via `upgrade` option - https://github.com/advisories/GHSA-4992-7rv2-5pvq

undici vulnerable to HTTP header injection via Set-Cookie percent-decoding - https://github.com/advisories/GHSA-p88m-4jfj-68fv

undici vulnerable to Set-Cookie SameSite attribute downgrade via permissive substring matching - https://github.com/advisories/GHSA-g8m3-5g58-fq7m

undici vulnerable to downstream response desynchronization via retry interceptor - https://github.com/advisories/GHSA-8xcm-r25x-g524

undici vulnerable to CRLF Injection via blob-like body 'type' property - https://github.com/advisories/GHSA-m8rv-5g2x-5cg5

undici vulnerable to cookie attribute injection via unsanitized domain and unparsed setCookie fields - https://github.com/advisories/GHSA-v3r7-h72x-cjcm

undici vulnerable to HTTP response queue poisoning via keep-alive socket reuse - https://github.com/advisories/GHSA-35p6-xmwp-9g52

undici vulnerable to downstream response splitting via retry interceptor - https://github.com/advisories/GHSA-r53p-7pc4-xj5r

undici vulnerable to Denial of Service via unrequested WebSocket subprotocol - https://github.com/advisories/GHSA-rfgv-xxqx-mfg5

undici vulnerable to Denial of Service via unbounded memory in the EventSource parser - https://github.com/advisories/GHSA-4qv8-2p9j-2685

undici vulnerable to TLS certificate validation bypass via dropped tls options in Agent - https://github.com/advisories/GHSA-2m5v-pch6-74hx

undici vulnerable to Denial of Service via TLS 1.2 certificate-changing renegotiation - https://github.com/advisories/GHSA-qrxm-fqhp-jwvm

undici WebSocket client vulnerable to Denial of Service via unbounded automatic PONG buffering - https://github.com/advisories/GHSA-9fm3-97px-rjf6

undici WebSocket client vulnerable to denial of service via fragment count bypass - https://github.com/advisories/GHSA-vxpw-j846-p89q

fix available via `npm audit fix --force`

Will install firebase@13.2.0, which is a breaking change

node_modules/undici

@firebase/auth 1.7.7-20240813205648 - 1.7.7-canary.1ff9661af || 1.7.8-20240827161511 - 1.7.9

Depends on vulnerable versions of undici

node_modules/@firebase/auth

firebase 0.900.22 || 7.9.1-0 - 7.9.1-canary.0396117e || 8.10.0-20217172214 - 8.10.0-canary.f40c0db53 || 9.0.0-20217250818 - 9.0.0-canary.d0d3acb10 || 9.0.1-2021727231341 - 9.0.1-canary.e039e1472 || 9.0.2-2021891633 - 9.0.2-canary.ff9baf70c || 9.0.3-202181503543 - 9.1.0-canary.f7d8324a1 || 9.1.1-2021830195733 - 9.1.1-canary.e70de6201 || 9.1.2-20219523556 - 9.1.2-canary.fc1d36497 || 9.22.1-20230524195328 || 10.12.2-20240523185724 - 10.12.2-canary.872e6f63e || 10.13.0-20240813205648 - 10.13.0-canary.fa0ed08fb || 10.13.1-20240827161511 - 10.14.1 || 11.9.0-20250603144652 - 11.9.0-canary.5871fd656

Depends on vulnerable versions of @firebase/auth

Depends on vulnerable versions of @firebase/auth-compat

Depends on vulnerable versions of @firebase/firestore

Depends on vulnerable versions of @firebase/firestore-compat

Depends on vulnerable versions of @firebase/functions

Depends on vulnerable versions of @firebase/functions-compat

Depends on vulnerable versions of @firebase/storage

Depends on vulnerable versions of @firebase/storage-compat

node_modules/firebase

@firebase/auth-compat 0.5.12-20240813205648 - 0.5.12-canary.fa0ed08fb || 0.5.13-20240827161511 - 0.5.14

Depends on vulnerable versions of @firebase/auth

Depends on vulnerable versions of undici

node_modules/@firebase/auth-compat

@firebase/firestore 4.7.0-20240813205648 - 4.7.0-canary.fa0ed08fb || 4.7.1-20240827161511 - 4.7.3

Depends on vulnerable versions of undici

node_modules/@firebase/firestore

@firebase/firestore-compat <=0.0.900-exp.520ca39d0 || 0.3.25-20240130223218 - 0.3.25-20240131233318 || 0.3.30-20240424141009 - 0.3.30-dataconnect-preview.f2ddc3d7b || 0.3.35-20240813205648 - 0.3.35-canary.fa0ed08fb || 0.3.36-20240827161511 - 0.3.38

Depends on vulnerable versions of @firebase/firestore

node_modules/@firebase/firestore-compat

@firebase/functions 0.11.7-20240827161511 - 0.11.8

Depends on vulnerable versions of undici

node_modules/@firebase/functions

@firebase/functions-compat 0.3.13-20240827161511 - 0.3.14

Depends on vulnerable versions of @firebase/functions

node_modules/@firebase/functions-compat

@firebase/storage 0.13.0-20240814182916 - 0.13.0-canary.fa0ed08fb || 0.13.1-20240827161511 - 0.13.2

Depends on vulnerable versions of undici

node_modules/@firebase/storage

@firebase/storage-compat <=0.0.900-exp.520ca39d0 || 0.1.4-202192711727 - 0.1.4-canary.f27fe4304 || 0.3.10-20240814182916 - 0.3.10-canary.fa0ed08fb || 0.3.11-20240827161511 - 0.3.12

Depends on vulnerable versions of @firebase/storage

node_modules/@firebase/storage-compat

uuid <11.1.1

Severity: moderate

uuid: Missing buffer bounds check in v3/v5/v6 when buf is provided - https://github.com/advisories/GHSA-w5hq-g745-h8pq

fix available via `npm audit fix --force`

Will install firebase-admin@14.5.0, which is a breaking change

node_modules/@genkit-ai/tools-common/node_modules/uuid

node_modules/@google-cloud/logging/node_modules/uuid

node_modules/@google-cloud/storage/node_modules/uuid

node_modules/eventid/node_modules/uuid

node_modules/firebase-tools/node_modules/uuid

node_modules/gaxios/node_modules/uuid

node_modules/google-gax/node_modules/uuid

node_modules/googleapis/node_modules/uuid

node_modules/jaeger-client/node_modules/uuid

node_modules/teeny-request/node_modules/uuid

node_modules/universal-analytics/node_modules/uuid

node_modules/uuid

@genkit-ai/tools-common *

Depends on vulnerable versions of adm-zip

Depends on vulnerable versions of glob

Depends on vulnerable versions of uuid

Depends on vulnerable versions of zod

node_modules/@genkit-ai/tools-common

@google-cloud/logging 0.8.0 - 11.2.3

Depends on vulnerable versions of @google-cloud/common

Depends on vulnerable versions of eventid

Depends on vulnerable versions of uuid

node_modules/@google-cloud/logging

eventid *

Depends on vulnerable versions of uuid

node_modules/eventid

googleapis-common <=7.2.0

Depends on vulnerable versions of uuid

node_modules/googleapis/node_modules/googleapis-common

googleapis 33.0.0 - 149.0.0

Depends on vulnerable versions of googleapis-common

node_modules/googleapis

@google-cloud/opentelemetry-cloud-monitoring-exporter <=0.21.0

Depends on vulnerable versions of googleapis

node_modules/@google-cloud/opentelemetry-cloud-monitoring-exporter

jaeger-client >=3.11.0

Depends on vulnerable versions of uuid

node_modules/jaeger-client

teeny-request 3.9.1 - 9.0.0

Depends on vulnerable versions of uuid

node_modules/teeny-request

@google-cloud/common 0.32.1 - 5.0.2

Depends on vulnerable versions of retry-request

Depends on vulnerable versions of teeny-request

node_modules/@google-cloud/common

retry-request 7.0.0 - 7.0.2

Depends on vulnerable versions of teeny-request

node_modules/retry-request

universal-analytics 0.4.7 - 0.5.3

Depends on vulnerable versions of uuid

node_modules/universal-analytics

websocket-driver <=0.7.4

Severity: critical

websocket-driver: Resource limit bypass via message compression - https://github.com/advisories/GHSA-mp7j-qc5w-4988

websocket-driver: Message corruption via abuse of protocol length headers - https://github.com/advisories/GHSA-xv26-6w52-cph6

fix available via `npm audit fix`

node_modules/websocket-driver

ws 7.0.0 - 7.5.10

Severity: high

ws: Memory exhaustion DoS from tiny fragments and data chunks - https://github.com/advisories/GHSA-96hv-2xvq-fx4p

fix available via `npm audit fix`

node_modules/ws

xlsx *

Severity: high

Prototype Pollution in sheetJS - https://github.com/advisories/GHSA-4r6h-8v6p-xvw6

SheetJS Regular Expression Denial of Service (ReDoS) - https://github.com/advisories/GHSA-5pgg-2g8v-p4x9

No fix available

node_modules/xlsx

yaml 2.0.0 - 2.8.2

Severity: moderate

yaml is vulnerable to Stack Overflow via deeply nested YAML collections - https://github.com/advisories/GHSA-48c2-rrv3-qjmp

fix available via `npm audit fix`

node_modules/yaml

zod <4.6.6

Severity: high

Zod can exhaust memory while validating oversized constrained collections - https://github.com/advisories/GHSA-mrhx-c7xc-m3w5

fix available via `npm audit fix --force`

Will install zod@4.6.7, which is a breaking change

node_modules/zod

163 vulnerabilities (6 low, 97 moderate, 49 high, 11 critical)

To address issues that do not require attention, run:

npm audit fix

To address all issues possible (including breaking changes), run:

npm audit fix --force

Some issues need review, and may require choosing

a different dependency.

~/workspace$ ^C

~/workspace$ ~/workspace$ npm audit

npm audit report

@babel/core <=7.29.0

@babel/core: Arbitrary File Read via sourceMappingURL Comment - https://github.com/advisories/GHSA-4x5r-pxfx-6jf8

fix available via `npm audit fix`

node_modules/@babel/core

@babel/plugin-transform-modules-systemjs 7.12.0 - 7.29.0

Severity: high

@babel/plugin-transform-modules-systemjs generates arbitrary code when compiling malicious input - https://github.com/advisories/GHSA-fv7c-fp4j-7gwp

fix available via `npm audit fix`

node_modules/@babel/plugin-transform-modules-systemjs

@capacitor/android 7.0.0 - 7.6.8

Severity: critical

Capacitor Android and iOS: remote content can be loaded at the app origin via the internal HTTP proxy path - https://github.com/advisories/GHSA-rvm3-566m-v7fv

fix available via `npm audit fix`

node_modules/@capacitor/android

@capacitor/ios 7.0.0 - 7.6.8

Severity: critical

Capacitor Android and iOS: remote content can be loaded at the app origin via the internal HTTP proxy path - https://github.com/advisories/GHSA-rvm3-566m-v7fv

fix available via `npm audit fix`

node_modules/@capacitor/ios

@fastify/busboy <=3.2.1

Severity: high

@fastify/busboy vulnerable to Denial of Service via oversized multipart boundary - https://github.com/advisories/GHSA-xjh9-v7x6-24jw

@fastify/busboy vulnerable to Denial of Service via prototype-named multipart part header - https://github.com/advisories/GHSA-x8mw-p69m-v3mx

@fastify/busboy vulnerable to CRLF injection via multipart Content-Disposition filename and name - https://github.com/advisories/GHSA-gxm5-99cw-xjw9

fix available via `npm audit fix`

node_modules/@fastify/busboy

@grpc/grpc-js <=1.13.5 || 1.14.0 - 1.14.4

Severity: high

@grpc/grpc-js: A malformed request can cause a server crash - https://github.com/advisories/GHSA-5375-pq7m-f5r2

@grpc/grpc-js: A malformed request can cause a server crash - https://github.com/advisories/GHSA-5375-pq7m-f5r2

@grpc/grpc-js: An incoming malformed compressed message can cause a client or server crash - https://github.com/advisories/GHSA-99f4-grh7-6pcq

@grpc/grpc-js: An incoming malformed compressed message can cause a client or server crash - https://github.com/advisories/GHSA-99f4-grh7-6pcq

@grpc/grpc-js: In certain configurations, getAuthContext can return unauthorized certificates as though they were authorized - https://github.com/advisories/GHSA-m9gg-hp2v-232j

@grpc/grpc-js: In certain configurations, getAuthContext can return unauthorized certificates as though they were authorized - https://github.com/advisories/GHSA-m9gg-hp2v-232j

@grpc/grpc-js: The server transmits some error messages thrown by method handlers to the client in status messages - https://github.com/advisories/GHSA-f596-whhp-79r4

@grpc/grpc-js: The server transmits some error messages thrown by method handlers to the client in status messages - https://github.com/advisories/GHSA-f596-whhp-79r4

fix available via `npm audit fix`

node_modules/@google-cloud/modelarmor/node_modules/@grpc/grpc-js

node_modules/@grpc/grpc-js

node_modules/google-gax/node_modules/@grpc/grpc-js

@hono/node-server <=1.19.14

Severity: high

@hono/node-server has authorization bypass for protected static paths via encoded slashes in Serve Static Middleware - https://github.com/advisories/GHSA-wc8c-qw6v-h7f6

@hono/node-server: Middleware bypass via repeated slashes in serveStatic - https://github.com/advisories/GHSA-92pp-h63x-v22m

Node.js Adapter for Hono: Path traversal in `serve-static` on Windows via encoded backslash (`%5C`) - https://github.com/advisories/GHSA-frvp-7c67-39w9

fix available via `npm audit fix`

node_modules/@hono/node-server

@isaacs/brace-expansion 5.0.0

Severity: high

@isaacs/brace-expansion has Uncontrolled Resource Consumption - https://github.com/advisories/GHSA-7h2j-956f-4vf2

fix available via `npm audit fix`

node_modules/@isaacs/brace-expansion

@modelcontextprotocol/sdk <=1.31.0

Severity: high

@modelcontextprotocol/sdk has cross-client data leak via shared server/transport instance reuse - https://github.com/advisories/GHSA-345p-7cg4-v4c7

Anthropic's MCP TypeScript SDK has a ReDoS vulnerability - https://github.com/advisories/GHSA-8r9q-7v3j-jr4g

MCP TypeScript SDK: OAuth client could send credentials to an authorization server chosen by the MCP server - https://github.com/advisories/GHSA-6qxp-vccf-f47h

MCP TypeScript SDK: Experimental tasks were not tied to the session that created them - https://github.com/advisories/GHSA-22jm-h49p-29qw

MCP TypeScript SDK: One HTTP request within the default size limit could exhaust server memory during validation - https://github.com/advisories/GHSA-46jr-4wx8-v453

MCP TypeScript SDK: Server bearer authentication accepted tokens issued for another service - https://github.com/advisories/GHSA-rvq5-wwqv-78pq

MCP TypeScript SDK: HTTP server transports and handlers did not limit request body size or JSON-RPC batch length - https://github.com/advisories/GHSA-f897-62hf-6gxq

MCP TypeScript client SDK: HTTP client transports and OAuth requests followed cross-origin redirects and re-sent custom headers and request bodies - https://github.com/advisories/GHSA-6prh-2h8m-c8cw

fix available via `npm audit fix`

node_modules/@modelcontextprotocol/sdk

@opentelemetry/core <2.8.0

Severity: moderate

OpenTelemetry Core: Unbounded memory allocation in W3C Baggage propagation - https://github.com/advisories/GHSA-8988-4f7v-96qf

fix available via `npm audit fix --force`

Will install genkit@0.5.17, which is a breaking change

node_modules/@opentelemetry/core

node_modules/@opentelemetry/exporter-jaeger/node_modules/@opentelemetry/core

node_modules/@opentelemetry/resource-detector-alibaba-cloud/node_modules/@opentelemetry/core

node_modules/@opentelemetry/resource-detector-container/node_modules/@opentelemetry/core

  @genkit-ai/core *

  Depends on vulnerable versions of @genkit-ai/firebase

  Depends on vulnerable versions of @opentelemetry/core

Depends on vulnerable versions of @opentelemetry/exporter-jaeger

Depends on vulnerable versions of @opentelemetry/sdk-metrics

Depends on vulnerable versions of @opentelemetry/sdk-node

Depends on vulnerable versions of @opentelemetry/sdk-trace-base

Depends on vulnerable versions of zod

node_modules/@genkit-ai/core

@genkit-ai/ai *

Depends on vulnerable versions of @genkit-ai/core

Depends on vulnerable versions of uuid

node_modules/@genkit-ai/ai

genkit <=0.5.0-rc.12 || 0.6.0-dev.2 - 1.0.0-rc.19 || >=1.0.4

Depends on vulnerable versions of @genkit-ai/ai

Depends on vulnerable versions of @genkit-ai/core

Depends on vulnerable versions of uuid

node_modules/genkit

@genkit-ai/google-cloud *

Depends on vulnerable versions of @google-cloud/opentelemetry-cloud-monitoring-exporter

Depends on vulnerable versions of @opentelemetry/auto-instrumentations-node

Depends on vulnerable versions of @opentelemetry/core

Depends on vulnerable versions of @opentelemetry/instrumentation-pino

Depends on vulnerable versions of @opentelemetry/resources

Depends on vulnerable versions of @opentelemetry/sdk-metrics

Depends on vulnerable versions of @opentelemetry/sdk-node

Depends on vulnerable versions of @opentelemetry/sdk-trace-base

node_modules/@genkit-ai/google-cloud

@genkit-ai/firebase >=0.5.4

Depends on vulnerable versions of @genkit-ai/google-cloud

node_modules/@genkit-ai/firebase

@genkit-ai/telemetry-server >=0.9.0-dev.1

Depends on vulnerable versions of @genkit-ai/tools-common

Depends on vulnerable versions of @google-cloud/firestore

Depends on vulnerable versions of @opentelemetry/core

Depends on vulnerable versions of @opentelemetry/sdk-metrics

Depends on vulnerable versions of @opentelemetry/sdk-node

Depends on vulnerable versions of @opentelemetry/sdk-trace-base

Depends on vulnerable versions of zod

node_modules/@genkit-ai/telemetry-server

@opentelemetry/exporter-jaeger *

Depends on vulnerable versions of @opentelemetry/core

Depends on vulnerable versions of @opentelemetry/sdk-trace-base

Depends on vulnerable versions of jaeger-client

node_modules/@opentelemetry/exporter-jaeger

@opentelemetry/exporter-trace-otlp-grpc <=0.218.0

Depends on vulnerable versions of @opentelemetry/core

Depends on vulnerable versions of @opentelemetry/otlp-grpc-exporter-base

Depends on vulnerable versions of @opentelemetry/otlp-transformer

Depends on vulnerable versions of @opentelemetry/resources

Depends on vulnerable versions of @opentelemetry/sdk-trace-base

node_modules/@opentelemetry/exporter-trace-otlp-grpc

@opentelemetry/sdk-node <=0.218.0

Depends on vulnerable versions of @opentelemetry/core

Depends on vulnerable versions of @opentelemetry/exporter-trace-otlp-grpc

Depends on vulnerable versions of @opentelemetry/exporter-trace-otlp-http

Depends on vulnerable versions of @opentelemetry/exporter-trace-otlp-proto

Depends on vulnerable versions of @opentelemetry/exporter-zipkin

Depends on vulnerable versions of @opentelemetry/resources

Depends on vulnerable versions of @opentelemetry/sdk-logs

Depends on vulnerable versions of @opentelemetry/sdk-metrics

Depends on vulnerable versions of @opentelemetry/sdk-trace-base

Depends on vulnerable versions of @opentelemetry/sdk-trace-node

node_modules/@opentelemetry/sdk-node

@opentelemetry/auto-instrumentations-node <=0.78.0

Depends on vulnerable versions of @opentelemetry/instrumentation-amqplib

Depends on vulnerable versions of @opentelemetry/instrumentation-aws-lambda

Depends on vulnerable versions of @opentelemetry/instrumentation-aws-sdk

Depends on vulnerable versions of @opentelemetry/instrumentation-cassandra-driver

Depends on vulnerable versions of @opentelemetry/instrumentation-connect

Depends on vulnerable versions of @opentelemetry/instrumentation-express

Depends on vulnerable versions of @opentelemetry/instrumentation-fastify

Depends on vulnerable versions of @opentelemetry/instrumentation-fs

Depends on vulnerable versions of @opentelemetry/instrumentation-hapi

Depends on vulnerable versions of @opentelemetry/instrumentation-http

Depends on vulnerable versions of @opentelemetry/instrumentation-knex

Depends on vulnerable versions of @opentelemetry/instrumentation-koa

Depends on vulnerable versions of @opentelemetry/instrumentation-mongodb

Depends on vulnerable versions of @opentelemetry/instrumentation-mongoose

Depends on vulnerable versions of @opentelemetry/instrumentation-mysql

Depends on vulnerable versions of @opentelemetry/instrumentation-mysql2

Depends on vulnerable versions of @opentelemetry/instrumentation-pg

Depends on vulnerable versions of @opentelemetry/instrumentation-pino

Depends on vulnerable versions of @opentelemetry/instrumentation-restify

Depends on vulnerable versions of @opentelemetry/instrumentation-tedious

Depends on vulnerable versions of @opentelemetry/instrumentation-undici

Depends on vulnerable versions of @opentelemetry/resource-detector-aws

Depends on vulnerable versions of @opentelemetry/resource-detector-azure

Depends on vulnerable versions of @opentelemetry/resource-detector-gcp

Depends on vulnerable versions of @opentelemetry/resources

Depends on vulnerable versions of @opentelemetry/sdk-node

node_modules/@opentelemetry/auto-instrumentations-node

@opentelemetry/exporter-trace-otlp-http <=0.218.0

Depends on vulnerable versions of @opentelemetry/core

Depends on vulnerable versions of @opentelemetry/otlp-exporter-base

Depends on vulnerable versions of @opentelemetry/otlp-transformer

Depends on vulnerable versions of @opentelemetry/resources

Depends on vulnerable versions of @opentelemetry/sdk-trace-base

node_modules/@opentelemetry/exporter-trace-otlp-http

@opentelemetry/exporter-trace-otlp-proto <=0.218.0

Depends on vulnerable versions of @opentelemetry/core

Depends on vulnerable versions of @opentelemetry/otlp-exporter-base

Depends on vulnerable versions of @opentelemetry/otlp-transformer

Depends on vulnerable versions of @opentelemetry/resources

Depends on vulnerable versions of @opentelemetry/sdk-trace-base

node_modules/@opentelemetry/exporter-trace-otlp-proto

@opentelemetry/exporter-zipkin <=2.7.1

Depends on vulnerable versions of @opentelemetry/core

Depends on vulnerable versions of @opentelemetry/resources

Depends on vulnerable versions of @opentelemetry/sdk-trace-base

node_modules/@opentelemetry/exporter-zipkin

@opentelemetry/instrumentation-amqplib <=0.46.1

Depends on vulnerable versions of @opentelemetry/core

node_modules/@opentelemetry/instrumentation-amqplib

@opentelemetry/instrumentation-aws-sdk <=0.49.1

Depends on vulnerable versions of @opentelemetry/core

node_modules/@opentelemetry/instrumentation-aws-sdk

@opentelemetry/instrumentation-connect <=0.43.1

Depends on vulnerable versions of @opentelemetry/core

node_modules/@opentelemetry/instrumentation-connect

@opentelemetry/instrumentation-express <=0.47.1

Depends on vulnerable versions of @opentelemetry/core

node_modules/@opentelemetry/instrumentation-express

@opentelemetry/instrumentation-fastify <=0.44.2

Depends on vulnerable versions of @opentelemetry/core

node_modules/@opentelemetry/instrumentation-fastify

@opentelemetry/instrumentation-fs <=0.19.1

Depends on vulnerable versions of @opentelemetry/core

node_modules/@opentelemetry/instrumentation-fs

@opentelemetry/instrumentation-hapi 0.24.0 - 0.45.2

Depends on vulnerable versions of @opentelemetry/core

node_modules/@opentelemetry/instrumentation-hapi

@opentelemetry/instrumentation-http <=0.16.0 || 0.19.1-alpha.7 - 0.218.0

Depends on vulnerable versions of @opentelemetry/core

node_modules/@opentelemetry/instrumentation-http

@opentelemetry/instrumentation-koa <=0.15.0 || 0.20.0 - 0.47.1

Depends on vulnerable versions of @opentelemetry/core

node_modules/@opentelemetry/instrumentation-koa

@opentelemetry/instrumentation-mongoose <=0.66.0

Depends on vulnerable versions of @opentelemetry/core

node_modules/@opentelemetry/instrumentation-mongoose

@opentelemetry/instrumentation-pino 0.41.0 - 0.46.1

Depends on vulnerable versions of @opentelemetry/core

node_modules/@opentelemetry/instrumentation-pino

@opentelemetry/instrumentation-restify 0.20.0 - 0.45.1

Depends on vulnerable versions of @opentelemetry/core

node_modules/@opentelemetry/instrumentation-restify

@opentelemetry/instrumentation-undici <=0.10.1

Depends on vulnerable versions of @opentelemetry/core

node_modules/@opentelemetry/instrumentation-undici

@opentelemetry/otlp-exporter-base <=0.218.0

Depends on vulnerable versions of @opentelemetry/core

Depends on vulnerable versions of @opentelemetry/otlp-transformer

node_modules/@opentelemetry/otlp-exporter-base

@opentelemetry/otlp-grpc-exporter-base <=0.218.0

Depends on vulnerable versions of @opentelemetry/core

Depends on vulnerable versions of @opentelemetry/otlp-exporter-base

Depends on vulnerable versions of @opentelemetry/otlp-transformer

node_modules/@opentelemetry/otlp-grpc-exporter-base

@opentelemetry/otlp-transformer <=0.218.0

Depends on vulnerable versions of @opentelemetry/core

Depends on vulnerable versions of @opentelemetry/resources

Depends on vulnerable versions of @opentelemetry/sdk-logs

Depends on vulnerable versions of @opentelemetry/sdk-metrics

Depends on vulnerable versions of @opentelemetry/sdk-trace-base

node_modules/@opentelemetry/otlp-transformer

@opentelemetry/propagator-b3 0.19.1-alpha.11 - 2.7.1

Depends on vulnerable versions of @opentelemetry/core

node_modules/@opentelemetry/propagator-b3

@opentelemetry/propagator-jaeger <=2.8.0

Depends on vulnerable versions of @opentelemetry/core

node_modules/@opentelemetry/propagator-jaeger

@opentelemetry/sdk-trace-node <=2.7.1

Depends on vulnerable versions of @opentelemetry/core

Depends on vulnerable versions of @opentelemetry/propagator-b3

Depends on vulnerable versions of @opentelemetry/propagator-jaeger

Depends on vulnerable versions of @opentelemetry/sdk-trace-base

node_modules/@opentelemetry/sdk-trace-node

@opentelemetry/resource-detector-alibaba-cloud <=0.30.1

Depends on vulnerable versions of @opentelemetry/core

Depends on vulnerable versions of @opentelemetry/resources

node_modules/@opentelemetry/resource-detector-alibaba-cloud

@opentelemetry/resource-detector-aws <=1.12.0

Depends on vulnerable versions of @opentelemetry/core

Depends on vulnerable versions of @opentelemetry/resources

node_modules/@opentelemetry/resource-detector-aws

@opentelemetry/resource-detector-azure <=0.6.1

Depends on vulnerable versions of @opentelemetry/core

Depends on vulnerable versions of @opentelemetry/resources

node_modules/@opentelemetry/resource-detector-azure

@opentelemetry/resource-detector-container <=0.6.1

Depends on vulnerable versions of @opentelemetry/core

Depends on vulnerable versions of @opentelemetry/resources

node_modules/@opentelemetry/resource-detector-container

@opentelemetry/resource-detector-gcp <=0.33.1

Depends on vulnerable versions of @opentelemetry/core

Depends on vulnerable versions of @opentelemetry/resources

node_modules/@opentelemetry/resource-detector-gcp

@opentelemetry/resources 0.8.0 - 2.7.1

Depends on vulnerable versions of @opentelemetry/core

node_modules/@opentelemetry/exporter-jaeger/node_modules/@opentelemetry/resources

node_modules/@opentelemetry/resources

@opentelemetry/instrumentation-aws-lambda <=0.45.0

Depends on vulnerable versions of @opentelemetry/resources

node_modules/@opentelemetry/instrumentation-aws-lambda

@opentelemetry/sdk-logs <=0.218.0

Depends on vulnerable versions of @opentelemetry/core

Depends on vulnerable versions of @opentelemetry/resources

node_modules/@opentelemetry/sdk-logs

@opentelemetry/sdk-metrics <=2.7.1

Depends on vulnerable versions of @opentelemetry/core

Depends on vulnerable versions of @opentelemetry/resources

node_modules/@opentelemetry/sdk-metrics

@opentelemetry/instrumentation-mongodb 0.35.0 - 0.47.0

Depends on vulnerable versions of @opentelemetry/sdk-metrics

node_modules/@opentelemetry/instrumentation-mongodb

@opentelemetry/sdk-trace-base <=2.7.1

Depends on vulnerable versions of @opentelemetry/core

Depends on vulnerable versions of @opentelemetry/resources

node_modules/@opentelemetry/exporter-jaeger/node_modules/@opentelemetry/sdk-trace-base

node_modules/@opentelemetry/sdk-trace-base

@opentelemetry/sql-common <=0.40.1

Depends on vulnerable versions of @opentelemetry/core

node_modules/@opentelemetry/sql-common

@opentelemetry/instrumentation-mysql2 <=0.66.0

Depends on vulnerable versions of @opentelemetry/sql-common

node_modules/@opentelemetry/instrumentation-mysql2

@opentelemetry/instrumentation-pg <=0.72.0

Depends on vulnerable versions of @opentelemetry/sql-common

node_modules/@opentelemetry/instrumentation-pg

@opentelemetry/instrumentation-cassandra-driver <0.66.0

Severity: moderate

Multiple @opentelemetry/instrumentation-* packages expose database username via unconditional db.user span attribute - https://github.com/advisories/GHSA-qqmp-wf37-98f9

fix available via `npm audit fix`

node_modules/@opentelemetry/instrumentation-cassandra-driver

@opentelemetry/instrumentation-knex <0.65.0

Severity: moderate

Multiple @opentelemetry/instrumentation-* packages expose database username via unconditional db.user span attribute - https://github.com/advisories/GHSA-qqmp-wf37-98f9

fix available via `npm audit fix`

node_modules/@opentelemetry/instrumentation-knex

@opentelemetry/instrumentation-mysql <0.67.0

Severity: moderate

Multiple @opentelemetry/instrumentation-* packages expose database username via unconditional db.user span attribute - https://github.com/advisories/GHSA-qqmp-wf37-98f9

fix available via `npm audit fix`

node_modules/@opentelemetry/instrumentation-mysql

@opentelemetry/instrumentation-tedious <0.40.0

Severity: moderate

Multiple @opentelemetry/instrumentation-* packages expose database username via unconditional db.user span attribute - https://github.com/advisories/GHSA-qqmp-wf37-98f9

fix available via `npm audit fix`

node_modules/@opentelemetry/instrumentation-tedious

@protobufjs/utf8 <=1.1.0

Severity: moderate

protobufjs has overlong UTF-8 decoding - https://github.com/advisories/GHSA-q6x5-8v7m-xcrf

fix available via `npm audit fix`

node_modules/@protobufjs/utf8

@tiptap/core <=3.30.4

Severity: high

Tiptap: mergeAttributes() turns an own __proto__ key into inherited executable DOM attributes - https://github.com/advisories/GHSA-cp6q-959q-f8rh

Tiptap: Quadratic ReDoS in block and inline Markdown attribute parsing - https://github.com/advisories/GHSA-j95f-988m-3j2f

fix available via `npm audit fix`

node_modules/@tiptap/core

@tootallnate/once <2.0.1

@tootallnate/once vulnerable to Incorrect Control Flow Scoping - https://github.com/advisories/GHSA-vpq2-c234-7xj6

fix available via `npm audit fix`

node_modules/@tootallnate/once

@xmldom/xmldom <=0.8.14

Severity: high

xmldom: XML injection via unsafe CDATA serialization allows attacker-controlled markup insertion - https://github.com/advisories/GHSA-wh4c-j3r5-mjhp

xmldom: Uncontrolled recursion in XML serialization leads to DoS - https://github.com/advisories/GHSA-2v35-w6hq-6mfw

xmldom has XML injection through unvalidated DocumentType serialization - https://github.com/advisories/GHSA-f6ww-3ggp-fr8h

xmldom has XML node injection through unvalidated processing instruction serialization - https://github.com/advisories/GHSA-x6wf-f3px-wcqx

xmldom has XML node injection through unvalidated comment serialization - https://github.com/advisories/GHSA-j759-j44w-7fr8

xmldom: XML fragment injection via invalid EntityReference.nodeName during requireWellFormed serialization - https://github.com/advisories/GHSA-6gmq-8vp8-gcm6

xmldom: Element name injection via createElement() bypasses requireWellFormed - https://github.com/advisories/GHSA-w2rr-34g9-rvrj

xmldom: Attribute name injection via setAttribute() bypasses requireWellFormed - https://github.com/advisories/GHSA-4w3w-2rp5-g8jm

xmldom: Processing Instruction Target Injection Bypasses requireWellFormed - https://github.com/advisories/GHSA-c7q8-3ch8-vqpv

xmldom: DocType `name` Injection Bypasses requireWellFormed - https://github.com/advisories/GHSA-27p8-2357-5qqv

xmldom: Parser silently accepts a not-well-formed end tag whose name is followed by a line break and trailing content - https://github.com/advisories/GHSA-6h8r-xr42-gp59

xmldom: Quadratic-time attribute deduplication - https://github.com/advisories/GHSA-8344-3jmq-59r6

xmldom: End-tag Whitespace-Trim Regex ReDoS — quadratic backtracking in the 0.8.x end-tag parser - https://github.com/advisories/GHSA-x4fp-j954-r2f4

xmldom: Quadratic-memory consumption - https://github.com/advisories/GHSA-965w-775f-mr7g

xmldom: Quadratic-time parsing via the malformed-input recovery path — `parseElementStartPart` re-scan and `normalize()` adjacent-text merge - https://github.com/advisories/GHSA-93r5-fhx6-vmg9

fix available via `npm audit fix`

node_modules/@xmldom/xmldom

adm-zip <=0.6.0

Severity: high

adm-zip: Crafted ZIP file triggers 4GB memory allocation - https://github.com/advisories/GHSA-xcpc-8h2w-3j85

adm-zip extraction follows destination symlinks, allowing arbitrary file overwrite - https://github.com/advisories/GHSA-vwc7-r8mq-g2x9

adm-zip: Uncontrolled memory allocation via the declared uncompressed size (DoS) - https://github.com/advisories/GHSA-7q85-xj36-vmfc

adm-zip: Decompression-bomb protection (fix for CVE-2026-39244) can be bypassed by declaring uncompressed size as 0 - https://github.com/advisories/GHSA-rcw4-f5rp-g42v

adm-zip extraction preserves SUID/SGID bits from untrusted ZIPs -> local privilege escalation - https://github.com/advisories/GHSA-j5f4-cc29-5x44

adm-zip: Duplicate ZIP entry names: getEntry() and extractAllTo() resolve to different content - https://github.com/advisories/GHSA-p634-w6r4-rjp2

adm-zip: getDataAsync() bypasses the maxOutputLength size guard enforced by the synchronous getData() path - https://github.com/advisories/GHSA-c6fg-446q-cg94

adm-zip: Unhandled error event in async DEFLATE decompression crashes Node.js process (DoS) - https://github.com/advisories/GHSA-8238-w5pm-2374

fix available via `npm audit fix`

node_modules/adm-zip

ajv <6.14.0 || >=7.0.0-alpha.0 <8.18.0

Severity: moderate

ajv has ReDoS when using `$data` option - https://github.com/advisories/GHSA-2g4f-4pwh-qvx6

ajv has ReDoS when using `$data` option - https://github.com/advisories/GHSA-2g4f-4pwh-qvx6

fix available via `npm audit fix`

node_modules/ajv

node_modules/schema-utils/node_modules/ajv

axios 1.0.0 - 1.19.0

Severity: high

Axios has a NO_PROXY Hostname Normalization Bypass that Leads to SSRF - https://github.com/advisories/GHSA-3p68-rc4w-qgx5

Axios: Authentication Bypass via Prototype Pollution Gadget in `validateStatus` Merge Strategy - https://github.com/advisories/GHSA-w9j2-pvgh-6h63

Axios: Incomplete Fix for CVE-2025-62718 — NO_PROXY Protection Bypassed via RFC 1122 Loopback Subnet (127.0.0.0/8) in Axios 1.15.0 - https://github.com/advisories/GHSA-pmwg-cvhr-8vh7

Axios: Invisible JSON Response Tampering via Prototype Pollution Gadget in `parseReviver` - https://github.com/advisories/GHSA-3w6x-2g7m-8v23

Axios: Null Byte Injection via Reverse-Encoding in AxiosURLSearchParams - https://github.com/advisories/GHSA-xhjh-pmcv-23jw

Axios: CRLF Injection in multipart/form-data body via unsanitized blob.type in formDataToStream - https://github.com/advisories/GHSA-445q-vr5w-6q77

Axios: no_proxy bypass via IP alias allows SSRF - https://github.com/advisories/GHSA-m7pr-hjqh-92cm

Axios' HTTP adapter-streamed uploads bypass maxBodyLength when maxRedirects: 0 - https://github.com/advisories/GHSA-5c9x-8gcm-mpgx

Axios: HTTP adapter streamed responses bypass maxContentLength - https://github.com/advisories/GHSA-vf2m-468p-8v99

Axios: Prototype Pollution Gadgets - Response Tampering, Data Exfiltration, and Request Hijacking - https://github.com/advisories/GHSA-pf86-5x62-jrwf

Axios: Header Injection via Prototype Pollution - https://github.com/advisories/GHSA-6chq-wfr3-2hj9

Axios: XSRF Token Cross-Origin Leakage via Prototype Pollution Gadget in `withXSRFToken` Boolean Coercion - https://github.com/advisories/GHSA-xx6v-rp6x-q39c

Axios is Vulnerable to Denial of Service via __proto__ Key in mergeConfig - https://github.com/advisories/GHSA-43fc-jf86-j433

Axios has prototype pollution read-side gadgets in HTTP adapter that allow credential injection and request hijacking - https://github.com/advisories/GHSA-q8qp-cvcw-x6jj

Axios has Unrestricted Cloud Metadata Exfiltration via Header Injection Chain - https://github.com/advisories/GHSA-fvcv-3m26-pcqx

Axios: unbounded recursion in toFormData causes DoS via deeply nested request data - https://github.com/advisories/GHSA-62hf-57xw-28j9

Axios: Regular Expression Denial of Service (ReDoS) via Cookie Name Injection - https://github.com/advisories/GHSA-hfxv-24rg-xrqf

Allocation of Resources Without Limits or Throttling in Axios - https://github.com/advisories/GHSA-777c-7fjr-54vf

Axios: Proxy-Authorization Credential Leak to Origin Server Across HTTP-to-HTTPS Redirect in Axios Node.js HTTP Adapter - https://github.com/advisories/GHSA-p92q-9vqr-4j8v

Axios: Proxy-Authorization header leaks to redirect target when proxy is re-evaluated to direct connection - https://github.com/advisories/GHSA-j5f8-grm9-p9fc

axios Vulnerable to Credential Theft and Response Hijacking via Prototype Pollution Gadget in Config Merge - https://github.com/advisories/GHSA-3g43-6gmg-66jw

axios Vulnerable to Full Man-in-the-Middle via Prototype Pollution Gadget in `config.proxy` - https://github.com/advisories/GHSA-35jp-ww65-95wh

axios has DoS & Header Injection via Prototype Pollution Read-Side Gadgets in axios merge functions - https://github.com/advisories/GHSA-898c-q2cr-xwhg

Axios: Prototype pollution gadgets can alter axios request construction - https://github.com/advisories/GHSA-mmx7-hfxf-jppx

Axios: Deep formToJSON Key Recursion Can Cause Denial of Service - https://github.com/advisories/GHSA-pmv8-rq9r-6j72

Axios: HTTP/2 streamed uploads bypass `maxBodyLength` - https://github.com/advisories/GHSA-mwf2-3pr3-8698

Axios: Nested axios option objects can consume polluted prototype values - https://github.com/advisories/GHSA-7q8q-rj6j-mhjq

Axios: Fetch adapter `ReadableStream` uploads bypass `maxBodyLength` - https://github.com/advisories/GHSA-jqh4-m9w3-8hp9

Axios: Excessive recursion in formDataToJSON can cause denial of service - https://github.com/advisories/GHSA-42h9-826w-cgv3

Axios: Prototype pollution gadget in fetch adapter can alter outbound requests - https://github.com/advisories/GHSA-vh66-26gq-q6x8

Axios: Prototype-Pollution Gadget in the Default Instance Allows Inherited Object.prototype.method to Override HTTP Method - https://github.com/advisories/GHSA-9fr6-4gfg-395g

Axios: HTTP/2 adapter bypasses configured DNS lookup and proxy controls - https://github.com/advisories/GHSA-3pq3-5fj3-cg6v

Axios: Denial of Service via Unhandled 'error' Event in HTTP/2 ClientHttp2Session Initialization - https://github.com/advisories/GHSA-542g-h47m-68v8

Axios: Header Injection via Inherited headers After Minimal Interceptor - https://github.com/advisories/GHSA-j8rh-479h-cp32

Axios: Fetch Adapter Header Injection via Inherited FormData getHeaders - https://github.com/advisories/GHSA-4hqw-qxg8-jxx2

fix available via `npm audit fix`

node_modules/axios

baseline-browser-mapping >=2.0.0 <2.11.0

Severity: moderate

baseline-browser-mapping process termination on invalid input causes denial of service - https://github.com/advisories/GHSA-w5vr-8v7q-w6rv

fix available via `npm audit fix`

node_modules/baseline-browser-mapping

basic-ftp <=6.2.0

Severity: critical

Basic FTP has Path Traversal Vulnerability in its downloadToDir() method - https://github.com/advisories/GHSA-5rq4-664w-9x2c

basic-ftp: Incomplete CRLF Injection Protection Allows Arbitrary FTP Command Execution via Credentials and MKD Commands - https://github.com/advisories/GHSA-6v7q-wjvx-w8wg

basic-ftp vulnerable to denial of service via unbounded memory consumption in Client.list() - https://github.com/advisories/GHSA-rp42-5vxx-qpwr

basic-ftp allows a malicious FTP server to cause client-side denial of service via unbounded multiline control response buffering - https://github.com/advisories/GHSA-rpmf-866q-6p89

basic-ftp: Quadratic-time CPU denial of service in Client.list() Unix directory-listing parser (RE_LINE backtracking) - https://github.com/advisories/GHSA-c475-qrg2-pj4r

fix available via `npm audit fix`

node_modules/basic-ftp

body-parser <=1.20.8 || 2.0.0-beta.1 - 2.3.0

Severity: high

body-parser vulnerable to denial of service when invalid limit value silently disables size enforcement - https://github.com/advisories/GHSA-v422-hmwv-36x6

body-parser vulnerable to denial of service when invalid limit value silently disables size enforcement - https://github.com/advisories/GHSA-v422-hmwv-36x6

body-parser vulnerable to Denial of Service via trailing bytes after a compressed request body - https://github.com/advisories/GHSA-27r3-jxmh-p828

body-parser vulnerable to Denial of Service via trailing bytes after a compressed request body - https://github.com/advisories/GHSA-27r3-jxmh-p828

Depends on vulnerable versions of qs

fix available via `npm audit fix`

node_modules/@modelcontextprotocol/sdk/node_modules/body-parser

node_modules/body-parser

brace-expansion <=1.1.20 || 2.0.0 - 2.1.6

Severity: high

brace-expansion: Zero-step sequence causes process hang and memory exhaustion - https://github.com/advisories/GHSA-f886-m6hf-6m8v

brace-expansion: Zero-step sequence causes process hang and memory exhaustion - https://github.com/advisories/GHSA-f886-m6hf-6m8v

brace-expansion: DoS via exponential-time expansion of consecutive non-expanding {} groups - https://github.com/advisories/GHSA-3jxr-9vmj-r5cp

brace-expansion: DoS via exponential-time expansion of consecutive non-expanding {} groups - https://github.com/advisories/GHSA-3jxr-9vmj-r5cp

brace-expansion: DoS via unbounded expansion length causing an out-of-memory process crash - https://github.com/advisories/GHSA-mh99-v99m-4gvg

brace-expansion: DoS via unbounded expansion length causing an out-of-memory process crash - https://github.com/advisories/GHSA-mh99-v99m-4gvg

brace-expansion: DoS via unbounded intermediate arrays, bypassing the CVE-2026-14257 mitigation - https://github.com/advisories/GHSA-rgw5-rvv9-x895

brace-expansion: DoS via unbounded intermediate arrays, bypassing the CVE-2026-14257 mitigation - https://github.com/advisories/GHSA-rgw5-rvv9-x895

brace-expansion: Quadratic-time expansion of the `{a},b}` rewrite causes CPU denial of service - https://github.com/advisories/GHSA-q2hr-2g5m-vwhr

brace-expansion: Quadratic-time expansion of the `{a},b}` rewrite causes CPU denial of service - https://github.com/advisories/GHSA-q2hr-2g5m-vwhr

brace-expansion: DoS via uncontrolled recursion on nested brace groups causing stack exhaustion - https://github.com/advisories/GHSA-qhr7-859c-m2p7

brace-expansion: DoS via uncontrolled recursion on nested brace groups causing stack exhaustion - https://github.com/advisories/GHSA-qhr7-859c-m2p7

brace-expansion: DoS via uncontrolled recursion in parseCommaParts causing stack exhaustion - https://github.com/advisories/GHSA-6j4f-fj2g-mc7p

brace-expansion: DoS via uncontrolled recursion in parseCommaParts causing stack exhaustion - https://github.com/advisories/GHSA-6j4f-fj2g-mc7p

fix available via `npm audit fix`

node_modules/brace-expansion

node_modules/filelist/node_modules/brace-expansion

node_modules/glob/node_modules/brace-expansion

node_modules/readdir-glob/node_modules/brace-expansion

node_modules/superstatic/node_modules/brace-expansion

browserslist <=4.28.6

Severity: high

Browserslist: Unbounded memory growth (no cache eviction) via distinct query results, leading to eventual OOM - https://github.com/advisories/GHSA-c83g-rgw3-j3cx

Browserslist: Uncaught crash / prototype write via untrusted browserslist-stats.json custom stats (normalizeStats) - https://github.com/advisories/GHSA-73wf-gq98-2v4g

fix available via `npm audit fix`

node_modules/browserslist

compression <1.8.2

Severity: high

compression vulnerable to Denial of Service via memory leak on premature response close - https://github.com/advisories/GHSA-vc2v-76pw-4v95

fix available via `npm audit fix`

node_modules/compression

csv-parse <7.0.2

Severity: moderate

node-csv: Prototype replacement still reachable via columns path - https://github.com/advisories/GHSA-8cw4-87c7-c6xx

fix available via `npm audit fix --force`

Will install firebase-tools@15.35.0, which is a breaking change

node_modules/csv-parse

firebase-tools *

Depends on vulnerable versions of @google-cloud/pubsub

Depends on vulnerable versions of archiver

Depends on vulnerable versions of csv-parse

Depends on vulnerable versions of exegesis

Depends on vulnerable versions of gaxios

Depends on vulnerable versions of glob

Depends on vulnerable versions of stream-json

Depends on vulnerable versions of tar

Depends on vulnerable versions of uuid

node_modules/firebase-tools

deepmerge >=4.2.0

deepmerge mergeObject() allows prototype poisoning of returned objects - https://github.com/advisories/GHSA-gcqx-w48m-w2h4

fix available via `npm audit fix --force`

Will install next-pwa@3.1.5, which is a breaking change

node_modules/deepmerge

@rollup/plugin-node-resolve >=8.0.0

Depends on vulnerable versions of deepmerge

node_modules/@rollup/plugin-node-resolve

workbox-build >=5.0.0-alpha.0

Depends on vulnerable versions of @rollup/plugin-node-resolve

Depends on vulnerable versions of rollup-plugin-terser

node_modules/workbox-build

workbox-webpack-plugin >=6.0.0-alpha.0

Depends on vulnerable versions of workbox-build

node_modules/workbox-webpack-plugin

next-pwa >=4.0.0-beta.0

Depends on vulnerable versions of workbox-webpack-plugin

node_modules/next-pwa

dompurify <=3.4.16

Severity: high

DOMPurify allows Cross-site Scripting (XSS) - https://github.com/advisories/GHSA-vhxf-7vqr-mrjg

DOMPurify contains a Cross-site Scripting vulnerability - https://github.com/advisories/GHSA-v8jm-5vwx-cfxm

DOMPurify contains a Cross-site Scripting vulnerability - https://github.com/advisories/GHSA-v2wj-7wpq-c8vv

DOMPurify: FORBID_TAGS bypassed by function-based ADD_TAGS predicate (asymmetry with FORBID_ATTR fix) - https://github.com/advisories/GHSA-h7mw-gpvr-xq4m

DOMPurify has a SAFE_FOR_TEMPLATES bypass in RETURN_DOM mode - https://github.com/advisories/GHSA-crv5-9vww-q3g8

DOMPurify: Cross-realm IN_PLACE sanitization leaves executable markup intact via realm-bound `instanceof` checks - https://github.com/advisories/GHSA-hpcv-96wg-7vj8

DOMPurify: IN_PLACE mode preserves attributes of a clobbered root element, allowing XSS via attacker-controlled root DOM - https://github.com/advisories/GHSA-r47g-fvhr-h676

DOMPurify IN_PLACE Sanitization Bypass via Attached Shadow Root Inside <template>.content - https://github.com/advisories/GHSA-rp9w-3fw7-7cwq

DOMPurify: Permanent `ALLOWED_ATTR` pollution via `setConfig()` bypassing the hook clone-guard (incomplete fix of the 3.4.7 hook-pollution patch) - https://github.com/advisories/GHSA-cmwh-pvxp-8882

DOMPurify: Trusted Types policy survives `clearConfig()` and can poison later `RETURN_TRUSTED_TYPE` output - https://github.com/advisories/GHSA-vxr8-fq34-vvx9

DOMPurify: `IN_PLACE` mode trusts attacker-controlled `nodeName` on live non-form nodes, allowing script retention and XSS via attacker-supplied DOM objects - https://github.com/advisories/GHSA-x4vx-rjvf-j5p4

DOMPurify: Hook mutation of `data.allowedTags` / `data.allowedAttributes` permanently pollutes `DEFAULT_ALLOWED_TAGS` / `DEFAULT_ALLOWED_ATTR` - https://github.com/advisories/GHSA-76mc-f452-cxcm

DOMPurify's ADD_TAGS function form bypasses FORBID_TAGS due to short-circuit evaluation - https://github.com/advisories/GHSA-39q2-94rc-95cp

DOMPurify ADD_ATTR predicate skips URI validation - https://github.com/advisories/GHSA-cjmm-f4jc-qw8r

DOMPurify USE_PROFILES prototype pollution allows event handlers - https://github.com/advisories/GHSA-cj63-jhhr-wcxv

DOMPurify is vulnerable to mutation-XSS via Re-Contextualization - https://github.com/advisories/GHSA-h8r8-wccr-v5f2

DOMPurify: IN_PLACE hook removal leaves a detached subtree executable, causing XSS - https://github.com/advisories/GHSA-55q2-fjhq-7xh7

DOMPurify: `CUSTOM_ELEMENT_HANDLING` bypasses `afterSanitizeElements` for allowed custom elements. - https://github.com/advisories/GHSA-c2j3-45gr-mqc4

DOMPurify: IN_PLACE returns a force-removed rawtext root whose text carries attacker markup — pure HTML reparse executes - https://github.com/advisories/GHSA-6688-9rhm-gjv2

DOMPurify IN_PLACE: hook that removes a parent or sibling leaves the detached subtree's event handlers armed (incomplete fix for GHSA-p98j-92pf-mc4p) - https://github.com/advisories/GHSA-mrv2-3pqr-j5jr

DOMPurify: SMIL attributeName=href guard is skipped when PARSER_MEDIA_TYPE is application/xhtml+xml - https://github.com/advisories/GHSA-c6gr-qvv4-5v3f

fix available via `npm audit fix --force`

Will install jspdf@4.2.1, which is a breaking change

node_modules/dompurify

jspdf <=4.2.0

Depends on vulnerable versions of dompurify

node_modules/jspdf

extract-zip *

Severity: high

extract-zip unvalidated symlink path traversal - https://github.com/advisories/GHSA-jmr9-qjv8-65gv

extract-zip allows arbitrary file writes through symlink archive entries - https://github.com/advisories/GHSA-7pqw-9j4j-h8q3

fix available via `npm audit fix`

node_modules/extract-zip

genkit-cli 0.9.0-dev.1 - 1.44.1

Depends on vulnerable versions of @genkit-ai/telemetry-server

Depends on vulnerable versions of @genkit-ai/tools-common

Depends on vulnerable versions of extract-zip

node_modules/genkit-cli

fast-uri 3.0.0 - 3.1.8

Severity: high

fast-uri vulnerable to host confusion via literal backslash authority delimiter - https://github.com/advisories/GHSA-v2hh-gcrm-f6hx

fast-uri vulnerable to host confusion via backslash authority introducer - https://github.com/advisories/GHSA-7p8r-x3mc-p8w7

fast-uri vulnerable to path traversal via percent-encoded dot segments - https://github.com/advisories/GHSA-q3j6-qgpj-74h6

fast-uri vulnerable to host confusion via percent-encoded authority delimiters - https://github.com/advisories/GHSA-v39h-62p7-jpjc

fast-uri vulnerable to server-side request forgery via malformed IPv6 normalization - https://github.com/advisories/GHSA-f65p-4m7j-42xc

fast-uri vulnerable to host confusion via percent-encoded scheme normalization - https://github.com/advisories/GHSA-jqff-g426-hqxp

fast-uri vulnerable to host confusion via failed IDN canonicalization - https://github.com/advisories/GHSA-4c8g-83qw-93j6

fast-uri vulnerable to authority injection via an unvalidated port in serialize - https://github.com/advisories/GHSA-qw65-cvwx-89v3

fast-uri vulnerable to inconsistent host case normalization via percent-encoded octets - https://github.com/advisories/GHSA-hrr3-gc8f-f4qj

fast-uri vulnerable to URI scheme spoofing via percent-encoded scheme decoding - https://github.com/advisories/GHSA-w74x-v6f9-j3xg

fast-uri vulnerable to improper path equivalence in relative reference normalization - https://github.com/advisories/GHSA-xhq7-xmqj-769h

fast-uri vulnerable to scheme injection via an unescaped first-segment colon in suffix references - https://github.com/advisories/GHSA-333x-w4r6-6crp

fix available via `npm audit fix`

node_modules/fast-uri

fast-xml-parser <=5.6.0

Severity: critical

fast-xml-parser has an entity encoding bypass via regex injection in DOCTYPE entity names - https://github.com/advisories/GHSA-m7jm-9gc2-mpf2

fast-xml-parser affected by DoS through entity expansion in DOCTYPE (no expansion limit) - https://github.com/advisories/GHSA-jmr7-xgp7-cmfj

fast-xml-parser has stack overflow in XMLBuilder with preserveOrder - https://github.com/advisories/GHSA-fj3w-jwp8-x2g3

fast-xml-parser affected by numeric entity expansion bypassing all entity expansion limits (incomplete fix for CVE-2026-26278) - https://github.com/advisories/GHSA-8gc5-j5rx-235r

Entity Expansion Limits Bypassed When Set to Zero Due to JavaScript Falsy Evaluation in fast-xml-parser - https://github.com/advisories/GHSA-jp2q-39xq-3w4g

fast-xml-parser XMLBuilder: XML Comment and CDATA Injection via Unescaped Delimiters - https://github.com/advisories/GHSA-gh4j-gqv2-49f6

fix available via `npm audit fix`

node_modules/fast-xml-parser

@google-cloud/storage 2.2.0 - 2.5.0 || 5.19.0 - 8.0.0

Depends on vulnerable versions of fast-xml-parser

Depends on vulnerable versions of retry-request

Depends on vulnerable versions of teeny-request

Depends on vulnerable versions of uuid

node_modules/@google-cloud/storage

fflate 0.8.0 - 0.8.2

Severity: moderate

fflate unzipSync can enter an infinite loop when parsing malformed ZIP64 archives - https://github.com/advisories/GHSA-px8p-9vwx-vf98

fix available via `npm audit fix`

node_modules/fflate

follow-redirects <=1.15.11

Severity: moderate

follow-redirects leaks Custom Authentication Headers to Cross-Domain Redirect Targets - https://github.com/advisories/GHSA-r4q5-vmmm-2653

fix available via `npm audit fix`

node_modules/follow-redirects

form-data >=4.0.0 <4.0.6 || <2.5.6

Severity: high

form-data: CRLF injection in form-data via unescaped multipart field names and filenames - https://github.com/advisories/GHSA-hmw2-7cc7-3qxx

form-data: CRLF injection in form-data via unescaped multipart field names and filenames - https://github.com/advisories/GHSA-hmw2-7cc7-3qxx

fix available via `npm audit fix`

node_modules/@types/request/node_modules/form-data

node_modules/form-data

glob 9.0.0 - 14.0.1

Severity: moderate

Glob: AbortSignal cancellation bypass allows post-timeout filesystem traversal - https://github.com/advisories/GHSA-3g3m-2fjr-6pw4

fix available via `npm audit fix --force`

Will install firebase-tools@15.35.0, which is a breaking change

node_modules/glob

node_modules/rimraf/node_modules/glob

archiver-utils >=5.0.1

Depends on vulnerable versions of glob

node_modules/archiver-utils

archiver 7.0.0 - 7.0.1

Depends on vulnerable versions of archiver-utils

Depends on vulnerable versions of zip-stream

node_modules/archiver

zip-stream 6.0.0 - 6.0.1

Depends on vulnerable versions of archiver-utils

node_modules/zip-stream

cacache >=17.0.5

Depends on vulnerable versions of glob

node_modules/cacache

make-fetch-happen >=13.0.0

Depends on vulnerable versions of cacache

node_modules/make-fetch-happen

node-gyp 10.0.0 - 12.2.0

Depends on vulnerable versions of make-fetch-happen

node_modules/node-gyp

re2 <=1.26.0

Depends on vulnerable versions of node-gyp

node_modules/re2

exegesis >=4.1.2

Depends on vulnerable versions of glob

node_modules/exegesis

rimraf 4.2.0 - 6.1.3

Depends on vulnerable versions of glob

node_modules/@google-cloud/cloud-sql-connector/node_modules/rimraf

node_modules/@google-cloud/modelarmor/node_modules/rimraf

node_modules/googleapis-common/node_modules/rimraf

node_modules/rimraf

gaxios 6.4.0 - 6.7.1 || 7.1.3

Depends on vulnerable versions of rimraf

Depends on vulnerable versions of uuid

node_modules/@google-cloud/cloud-sql-connector/node_modules/gaxios

node_modules/@google-cloud/modelarmor/node_modules/gaxios

node_modules/gaxios

node_modules/googleapis-common/node_modules/gaxios

google-gax 4.0.5-experimental - 4.6.1 || 5.0.5 - 5.0.8

Depends on vulnerable versions of retry-request

Depends on vulnerable versions of rimraf

Depends on vulnerable versions of uuid

node_modules/@google-cloud/modelarmor/node_modules/google-gax

node_modules/google-gax

@google-cloud/firestore 7.5.0-pre.0 || 7.6.0 - 7.11.6

Depends on vulnerable versions of google-gax

node_modules/@google-cloud/firestore

firebase-admin 10.2.0 - 13.10.0

Depends on vulnerable versions of @google-cloud/firestore

Depends on vulnerable versions of uuid

node_modules/firebase-admin

@google-cloud/pubsub 2.11.1-pre || 4.3.0 - 4.11.0

Depends on vulnerable versions of google-gax

node_modules/@google-cloud/pubsub

handlebars 3.0.0 - 4.7.9

Severity: critical

Handlebars.js has JavaScript Injection via AST Type Confusion by tampering @partial-block - https://github.com/advisories/GHSA-3mfm-83xf-c92r

Handlebars.js has JavaScript Injection via AST Type Confusion - https://github.com/advisories/GHSA-2w6w-674q-4c4q

Handlebars.js has Prototype Pollution Leading to XSS through Partial Template Injection - https://github.com/advisories/GHSA-2qvq-rjwj-gvw9

Handlebars.js has a Prototype Method Access Control Gap via Missing __lookupSetter__ Blocklist Entry - https://github.com/advisories/GHSA-7rx3-28cr-v5wh

Handlebars.js has a Property Access Validation Bypass in container.lookup - https://github.com/advisories/GHSA-442j-39wm-28r2

Handlebars.js has JavaScript Injection via AST Type Confusion when passing an object as dynamic partial - https://github.com/advisories/GHSA-xhpv-hc6g-r9c6

Handlebars.js has Denial of Service via Malformed Decorator Syntax in Template Compilation - https://github.com/advisories/GHSA-9cx6-37pm-9jff

Handlebars.js has JavaScript Injection in CLI Precompiler via Unescaped Names and Options - https://github.com/advisories/GHSA-xjpj-3mr7-gcpf

Handlebars: JavaScript Injection via Unsafe Inline Embedding of Precompiled Templates - https://github.com/advisories/GHSA-xw65-4hp5-5hc7

Handlebars: JavaScript Injection via AST Type Confusion in compile (bypass of CVE-2026-33937) - https://github.com/advisories/GHSA-8r5x-fm3f-whwj

Handlebars: JavaScript Injection via Own Property Check Bypass - https://github.com/advisories/GHSA-p8wg-vrv2-v86f

fix available via `npm audit fix`

node_modules/handlebars

ip-address <=10.7.3

Severity: high

ip-address has XSS in Address6 HTML-emitting methods - https://github.com/advisories/GHSA-v2v4-37r5-5v8g

ip-address: Address4 decodes leading-zero octets as decimal while resolvers decode them as octal, allowing SSRF and trust-boundary bypass - https://github.com/advisories/GHSA-mwp4-54f8-5fhr

ip-address: Address6.isLinkLocal() recognizes fe80::/64 rather than fe80::/10, allowing SSRF and trust-boundary bypass to on-link hosts - https://github.com/advisories/GHSA-rpw4-54j3-4h4q

ip-address: isInSubnet() and isHostInSubnet() compare addresses of different families as if they shared an address space, allowing an allowlist check to admit an address outside its range - https://github.com/advisories/GHSA-j6r3-76f7-8jcv

ip-address: Address6 builds a parse diagnostic proportional to the input with no length bound, allowing a single long string to stall or crash the process - https://github.com/advisories/GHSA-h3mg-xc3c-68pw

ip-address: Address6 matches a zone identifier in quadratic time ahead of its length limit, allowing a single long string to stall the process - https://github.com/advisories/GHSA-rxp7-6hxx-x8q5

fix available via `npm audit fix`

node_modules/ip-address

js-yaml <=3.15.1 || 4.0.0 - 4.3.1

Severity: high

JS-YAML: Quadratic-complexity DoS in merge key handling via repeated aliases - https://github.com/advisories/GHSA-h67p-54hq-rp68

JS-YAML: Quadratic-complexity DoS in merge key handling via repeated aliases - https://github.com/advisories/GHSA-h67p-54hq-rp68

js-yaml: YAML merge-key chains can force quadratic CPU consumption - https://github.com/advisories/GHSA-52cp-r559-cp3m

js-yaml: YAML merge-key chains can force quadratic CPU consumption - https://github.com/advisories/GHSA-52cp-r559-cp3m

JS-YAML: Quadratic CPU consumption in !!omap resolution (3.x and 4.x) — CVE-2026-59870 fix not backported - https://github.com/advisories/GHSA-5p4m-2wfm-xmqj

JS-YAML: Quadratic CPU consumption in !!omap resolution (3.x and 4.x) — CVE-2026-59870 fix not backported - https://github.com/advisories/GHSA-5p4m-2wfm-xmqj

js-yaml: maxTotalMergeKeys does not limit CPU use for empty merge sources - https://github.com/advisories/GHSA-2883-xcg3-v3hh

js-yaml: maxTotalMergeKeys does not limit CPU use for empty merge sources - https://github.com/advisories/GHSA-2883-xcg3-v3hh

fix available via `npm audit fix`

node_modules/@apidevtools/json-schema-ref-parser/node_modules/js-yaml

node_modules/@genkit-ai/tools-common/node_modules/js-yaml

node_modules/js-yaml

json-2-csv 3.15.0 - 5.5.10

Severity: moderate

json-2-csv vulnerable to CSV Injection via the preventCsvInjection optio - https://github.com/advisories/GHSA-g27c-q7cp-mhx6

fix available via `npm audit fix`

node_modules/json-2-csv

linkify-it <=5.0.1

Severity: high

LinkifyIt#match scan loop has quadratic algorithmic complexity - https://github.com/advisories/GHSA-22p9-wv53-3rq4

linkify-it: Quadratic-complexity DoS via the `mailto:` validator scan-loop on attacker text - https://github.com/advisories/GHSA-v245-v573-v5vm

fix available via `npm audit fix`

node_modules/linkify-it

lodash 4.0.0 - 4.17.23

Severity: high

lodash vulnerable to Code Injection via `_.template` imports key names - https://github.com/advisories/GHSA-r5fr-rjxr-66jc

Lodash has Prototype Pollution Vulnerability in `_.unset`, `_.omit`, and `_.pullAt` functions - https://github.com/advisories/GHSA-xxjr-mmjv-4gpg

fix available via `npm audit fix`

node_modules/lodash

markdown-it <=14.3.2

Severity: high

markdown-it: Quadratic complexity DoS in smartquotes rule via replaceAt string operations - https://github.com/advisories/GHSA-6v5v-wf23-fmfq

markdown-it: Quadratic complexity in smartquotes with unmatched closing quotes - https://github.com/advisories/GHSA-r7fv-28h4-cvq7

markdown-it: Quadratic-time denial of service in inline HTML parsing with html enabled - https://github.com/advisories/GHSA-vfgh-jcmw-g37q

markdown-it: Quadratic-time rendering of a single multi-line link reference definition with default options (regression since 14.0) - https://github.com/advisories/GHSA-gfr2-rv44-r23c

markdown-it linkify: true has two quadratic paths, so a few hundred KB of markdown blocks the event loop for tens of seconds - https://github.com/advisories/GHSA-253c-mchw-3w2r

fix available via `npm audit fix`

node_modules/markdown-it

minimatch <=3.1.3 || 5.0.0 - 5.1.7 || 6.0.0 - 6.2.1 || 7.0.0 - 11.0.0

Severity: high

minimatch has a ReDoS via repeated wildcards with non-matching literal in pattern - https://github.com/advisories/GHSA-3ppc-4f35-3m26

minimatch has a ReDoS via repeated wildcards with non-matching literal in pattern - https://github.com/advisories/GHSA-3ppc-4f35-3m26

minimatch has a ReDoS via repeated wildcards with non-matching literal in pattern - https://github.com/advisories/GHSA-3ppc-4f35-3m26

minimatch has a ReDoS via repeated wildcards with non-matching literal in pattern - https://github.com/advisories/GHSA-3ppc-4f35-3m26

minimatch has a ReDoS via repeated wildcards with non-matching literal in pattern - https://github.com/advisories/GHSA-3ppc-4f35-3m26

minimatch has ReDoS: matchOne() combinatorial backtracking via multiple non-adjacent GLOBSTAR segments - https://github.com/advisories/GHSA-7r86-cg39-jmmj

minimatch has ReDoS: matchOne() combinatorial backtracking via multiple non-adjacent GLOBSTAR segments - https://github.com/advisories/GHSA-7r86-cg39-jmmj

minimatch has ReDoS: matchOne() combinatorial backtracking via multiple non-adjacent GLOBSTAR segments - https://github.com/advisories/GHSA-7r86-cg39-jmmj

minimatch has ReDoS: matchOne() combinatorial backtracking via multiple non-adjacent GLOBSTAR segments - https://github.com/advisories/GHSA-7r86-cg39-jmmj

minimatch has ReDoS: matchOne() combinatorial backtracking via multiple non-adjacent GLOBSTAR segments - https://github.com/advisories/GHSA-7r86-cg39-jmmj

minimatch ReDoS: nested *() extglobs generate catastrophically backtracking regular expressions - https://github.com/advisories/GHSA-23c5-xmqv-rm74

minimatch ReDoS: nested *() extglobs generate catastrophically backtracking regular expressions - https://github.com/advisories/GHSA-23c5-xmqv-rm74

minimatch ReDoS: nested *() extglobs generate catastrophically backtracking regular expressions - https://github.com/advisories/GHSA-23c5-xmqv-rm74

minimatch ReDoS: nested *() extglobs generate catastrophically backtracking regular expressions - https://github.com/advisories/GHSA-23c5-xmqv-rm74

minimatch ReDoS: nested *() extglobs generate catastrophically backtracking regular expressions - https://github.com/advisories/GHSA-23c5-xmqv-rm74

minimatch has potential denial of service via globparts amplification - https://github.com/advisories/GHSA-g3hv-75wg-m249

fix available via `npm audit fix`

node_modules/filelist/node_modules/minimatch

node_modules/glob/node_modules/minimatch

node_modules/minimatch

node_modules/readdir-glob/node_modules/minimatch

node_modules/rimraf/node_modules/minimatch

node_modules/superstatic/node_modules/minimatch

morgan <=1.12.0

Severity: moderate

morgan vulnerable to Log Forging via unneutralized control characters in :remote-user - https://github.com/advisories/GHSA-4vj7-5mj6-jm8m

morgan vulnerable to Log Forging via unescaped Unicode line separators - https://github.com/advisories/GHSA-jxfw-x594-9x9m

morgan vulnerable to Log Injection via unescaped double quote in quoted log fields - https://github.com/advisories/GHSA-9f6g-j8ch-79g4

fix available via `npm audit fix`

node_modules/morgan

nanoid <=3.3.17

Severity: high

nanoid: non-secure generators can loop indefinitely with negative size - https://github.com/advisories/GHSA-28wg-ghj8-5hjv

nanoid: custom generators can loop indefinitely when size is zero - https://github.com/advisories/GHSA-2v37-7h3g-55p8

nanoid: Integer Overflow or Wraparound - https://github.com/advisories/GHSA-xwg4-73v4-xw9w

fix available via `npm audit fix`

node_modules/nanoid

next 9.3.4-canary.0 - 16.4.0

Severity: critical

Next.js self-hosted applications vulnerable to DoS via Image Optimizer remotePatterns configuration - https://github.com/advisories/GHSA-9g9p-9gw9-jx7f

Next.js HTTP request deserialization can lead to DoS when using insecure React Server Components - https://github.com/advisories/GHSA-h25m-26qc-wcjf

Next.js: HTTP request smuggling in rewrites - https://github.com/advisories/GHSA-ggv3-7p47-pfv8

Next.js: Unbounded next/image disk cache growth can exhaust storage - https://github.com/advisories/GHSA-3x4c-7xq6-9pq8

Next.js: Unbounded postponed resume buffering can lead to DoS - https://github.com/advisories/GHSA-h27x-g6w4-24gq

Next.js: null origin can bypass Server Actions CSRF checks - https://github.com/advisories/GHSA-mq59-m269-xvcx

Next.js: null origin can bypass dev HMR websocket CSRF checks - https://github.com/advisories/GHSA-jcc7-9wpm-mj36

Next.js has Unbounded Memory Consumption via PPR Resume Endpoint - https://github.com/advisories/GHSA-5f7q-jpqc-wp7h

Next.js has a Denial of Service with Server Components - https://github.com/advisories/GHSA-q4gf-8mx6-v5v3

Next.js Vulnerable to Denial of Service with Server Components - https://github.com/advisories/GHSA-8h8q-6873-q5fj

Next.js's Middleware / Proxy redirects can be cache-poisoned - https://github.com/advisories/GHSA-3g8h-86w9-wvmq

Next.js vulnerable to cross-site scripting in App Router applications using CSP nonces - https://github.com/advisories/GHSA-ffhc-5mcf-pf4q

Next.js vulnerable to cache poisoning via collisions in React Server Component cache-busting - https://github.com/advisories/GHSA-vfv6-92ff-j949

Next.js has cross-site scripting in beforeInteractive scripts with untrusted input - https://github.com/advisories/GHSA-gx5p-jg67-6x7h

Next.js vulnerable to Denial of Service via connection exhaustion in applications using Cache Components - https://github.com/advisories/GHSA-mg66-mrh9-m8jx

Next.js has a Denial of Service in the Image Optimization API - https://github.com/advisories/GHSA-h64f-5h5j-jqjh

Next.js vulnerable to server-side request forgery in applications using WebSocket upgrades - https://github.com/advisories/GHSA-c4j6-fc7j-m34r

Next.js has a Middleware / Proxy bypass through dynamic route parameter injection - https://github.com/advisories/GHSA-492v-c6pp-mqqv

Next.js vulnerable to cache poisoning in React Server Component responses - https://github.com/advisories/GHSA-wfc6-r584-vfw7

Next.js has a Middleware / Proxy bypass in App Router applications via segment-prefetch routes - https://github.com/advisories/GHSA-267c-6grr-h53f

Next.js has a Middleware / Proxy bypass in Pages Router applications using i18n - https://github.com/advisories/GHSA-36qx-fr4f-26g5

Next.js: Middleware / Proxy bypass in App Router applications using Turbopack and single locale - https://github.com/advisories/GHSA-6gpp-xcg3-4w24

Next.js: Denial of Service in App Router using Server Actions - https://github.com/advisories/GHSA-m99w-x7hq-7vfj

Next.js: Server-Side Request Forgery in Server Actions on custom servers - https://github.com/advisories/GHSA-89xv-2m56-2m9x

Next.js: Cache confusion of response bodies for requests with bodies - https://github.com/advisories/GHSA-68g3-v927-f742

Next.js: Cache confusion of response bodies for requests with bodies containing invalid UTF-8 byte sequences - https://github.com/advisories/GHSA-4633-3j49-mh5q

Next.js: Unbounded Server Action payload in Edge runtime - https://github.com/advisories/GHSA-4c39-4ccg-62r3

Next.js: Server-Side Request Forgery in rewrites via attacker-controlled destination hostname - https://github.com/advisories/GHSA-p9j2-gv94-2wf4

Next.js: Denial of Service in the Image Optimization API using SVGs - https://github.com/advisories/GHSA-q8wf-6r8g-63ch

Next.js: Unauthenticated disclosure of internal Server Function endpoints - https://github.com/advisories/GHSA-955p-x3mx-jcvp

Next.js: Unauthenticated Remote Code Execution on windows-hosted servers - https://github.com/advisories/GHSA-p293-qw3h-jr36

Next.js: Unauthenticated Remote Code Execution in Image Optimization API when AVIF files are used - https://github.com/advisories/GHSA-2xp9-vwfh-vxw4

Next.js has cache poisoning of SSG and ISR pages in self-hosted applications - https://github.com/advisories/GHSA-4jqv-mc3x-m676

Next.js has information disclosure in development server's Model Context Protocol endpoint - https://github.com/advisories/GHSA-39w2-rjm5-chcv

Next.js has information disclosure in App Router metadata image routes via dynamicParams bypass - https://github.com/advisories/GHSA-f87g-xv8r-7p7x

Next.js has cache poisoning in SSG/ISR rendering that leads to cross-user content substitution and persistent denial of service - https://github.com/advisories/GHSA-mcj8-r9mp-w47p

Next.js has Server-Side Request Forgery in Image Optimization - https://github.com/advisories/GHSA-cjq9-62q9-8jv4

Next.js: Unauthenticated Remote Code Execution in Image Optimization API when SVG files are used - https://github.com/advisories/GHSA-2464-fhr4-w9xw

Next.js: Denial of Service in App Router using Server Actions - https://github.com/advisories/GHSA-p3m5-59mp-jv5r

Next.js: Unauthenticated Remote Code Execution in `use cache` functions returning typed arrays - https://github.com/advisories/GHSA-673q-mjm6-r5xr

Next.js has a Middleware / Proxy bypass in App Router applications via segment-prefetch routes - Incomplete Fix Follow-Up - https://github.com/advisories/GHSA-26hh-7cqf-hhc6

Depends on vulnerable versions of postcss

Depends on vulnerable versions of sharp

fix available via `npm audit fix`

node_modules/next

node-forge <=1.4.0

Severity: high

node-forge RSA PKCS#1 v1.5 signature verification accepts extra nested DigestAlgorithm elements - https://github.com/advisories/GHSA-86w9-cpqp-85rv

Forge: ASN.1 OID first arc truncation in asn1.oidToDer - https://github.com/advisories/GHSA-4642-5mcj-2rqw

Forge: Prototype Pollution in forge.http cookie handling via a malicious Set-Cookie - https://github.com/advisories/GHSA-6wvx-3r32-xmcg

Forge: TLS client crash when the server sends no certificate - https://github.com/advisories/GHSA-525v-9gp9-w22h

Forge: Regular expression denial of service in PEM decoding (pem.decode) - https://github.com/advisories/GHSA-7wch-p9px-956x

Forge: Denial of Service via infinite loop in BigInteger.modInverse() with negative input (incomplete fix of CVE-2026-33891) - https://github.com/advisories/GHSA-h6cr-wjv9-3cpp

Forge: verifyCertificateChain() removes trusted CA certificates with the same subject from the CA store - https://github.com/advisories/GHSA-4487-j8r4-4g2f

Forge: AES-GCM authentication bypass via unvalidated tagLength option - https://github.com/advisories/GHSA-5cwg-6vw7-rj6p

Forge: PKCS#12 MAC forgery and constant-key PBE via zero iteration count - https://github.com/advisories/GHSA-jc66-7q78-782g

Forge: Denial of service in TLS record processing via a record interleaved with a fragmented handshake message - https://github.com/advisories/GHSA-8hrf-8g6f-7xwp

Forge: Denial of service in TLS record processing via call stack exhaustion - https://github.com/advisories/GHSA-hqq3-7jhf-c5jx

Forge: X.509 basicConstraints bypass in verifyCertificateChain() via deprecated extension OIDs 2.5.29.10 and 2.5.29.13 - https://github.com/advisories/GHSA-5x38-2vff-x55p

fix available via `npm audit fix`

node_modules/node-forge

path-to-regexp <=0.1.12 || 8.0.0 - 8.3.0

Severity: high

path-to-regexp vulnerable to Regular Expression Denial of Service via multiple route parameters - https://github.com/advisories/GHSA-37ch-88jc-xwx2

path-to-regexp vulnerable to Denial of Service via sequential optional groups - https://github.com/advisories/GHSA-j3q9-mxjg-w52f

path-to-regexp vulnerable to Regular Expression Denial of Service via multiple wildcards - https://github.com/advisories/GHSA-27v5-c462-wpq7

fix available via `npm audit fix`

node_modules/path-to-regexp

node_modules/router/node_modules/path-to-regexp

picomatch <=2.3.1 || 4.0.0 - 4.0.3

Severity: high

Picomatch: Method Injection in POSIX Character Classes causes incorrect Glob Matching - https://github.com/advisories/GHSA-3v7f-55p6-f55p

Picomatch: Method Injection in POSIX Character Classes causes incorrect Glob Matching - https://github.com/advisories/GHSA-3v7f-55p6-f55p

Picomatch has a ReDoS vulnerability via extglob quantifiers - https://github.com/advisories/GHSA-c2c7-rcm5-vvqj

Picomatch has a ReDoS vulnerability via extglob quantifiers - https://github.com/advisories/GHSA-c2c7-rcm5-vvqj

fix available via `npm audit fix`

node_modules/picomatch

node_modules/tinyglobby/node_modules/picomatch

postcss <=8.5.22

Severity: high

PostCSS has XSS via Unescaped </style> in its CSS Stringify Output - https://github.com/advisories/GHSA-qx2v-qp2m-jg93

PostCSS: Arbitrary file read and information disclosure via attacker-controlled sourceMappingURL in CSS comments - https://github.com/advisories/GHSA-6g55-p6wh-862q

PostCSS: incomplete fix of GHSA-6g55-p6wh-862q — attacker-controlled sourceMappingURL reads arbitrary .map files when `from` is unset - https://github.com/advisories/GHSA-fxqj-rqcc-2cmp

PostCSS: Path Traversal in Previous Source Map Auto-Loading (sourceMappingURL) leads to Arbitrary .map File Disclosure - https://github.com/advisories/GHSA-r28c-9q8g-f849

fix available via `npm audit fix`

node_modules/next/node_modules/postcss

node_modules/postcss

postcss-selector-parser <=6.1.4

Severity: moderate

postcss-selector-parser allows denial of service through uncontrolled AST recursion - https://github.com/advisories/GHSA-w9m9-85wc-3x92

PostCSS: Quadratic complexity in flat selector parsing allows CPU exhaustion - https://github.com/advisories/GHSA-rj75-hqrm-r3gf

fix available via `npm audit fix`

node_modules/postcss-selector-parser

prosemirror-view <1.42.3

Severity: high

ProseMirror has a XSS vulnerability in prosemirror-view's paste handling - https://github.com/advisories/GHSA-c8x8-7fp4-3x9w

fix available via `npm audit fix`

node_modules/prosemirror-view

protobufjs <=7.6.4

Severity: critical

protobuf.js: Code injection through bytes field defaults in generated toObject code - https://github.com/advisories/GHSA-66ff-xgx4-vchm

protobuf.js: Denial of service from crafted field names in generated code - https://github.com/advisories/GHSA-2pr8-phx7-x9h3

protobuf.js: Prototype injection in generated message constructors - https://github.com/advisories/GHSA-fx83-v9x8-x52w

protobuf.js: Code generation gadget after prototype pollution - https://github.com/advisories/GHSA-75px-5xx7-5xc7

protobuf.js: Process-wide denial of service through unsafe option paths - https://github.com/advisories/GHSA-jvwf-75h9-cwgg

protobuf.js: Denial of service through unbounded protobuf recursion - https://github.com/advisories/GHSA-685m-2w69-288q

protobufjs has overlong UTF-8 decoding - https://github.com/advisories/GHSA-q6x5-8v7m-xcrf

protobufjs: Denial of Service via unbounded recursive JSON descriptor expansion - https://github.com/advisories/GHSA-jggg-4jg4-v7c6

protobufjs: Denial of service through unbounded Any expansion during JSON conversion - https://github.com/advisories/GHSA-wcpc-wj8m-hjx6

protobufjs : Schema-derived names can shadow runtime-significant properties - https://github.com/advisories/GHSA-f38q-mgvj-vph7

protobufjs: Denial of Service via infinite loop in .proto option parsing - https://github.com/advisories/GHSA-j3f2-48v5-ccww

protobufjs has an arbitrary code execution issue - https://github.com/advisories/GHSA-xq3m-2v4x-88gg

fix available via `npm audit fix`

node_modules/protobufjs

proxy-addr 1.1.0 - 2.0.7

Severity: critical

proxy-addr vulnerable to IP spoofing via IPv4-mapped IPv6 trust subnet - https://github.com/advisories/GHSA-jqcg-44mw-7w3h

fix available via `npm audit fix`

node_modules/proxy-addr

qs <=6.16.0

Severity: moderate

qs's arrayLimit bypass in comma parsing allows denial of service - https://github.com/advisories/GHSA-w7fw-mjwx-w883

qs's arrayLimit bypass in its bracket notation allows DoS via memory exhaustion - https://github.com/advisories/GHSA-6rw7-vpxm-498p

qs has a remotely triggerable DoS: qs.stringify crashes with TypeError on null/undefined entries in comma-format arrays when encodeValuesOnly is set - https://github.com/advisories/GHSA-q8mj-m7cp-5q26

qs: Denial of Service via Attacker Controlled isBuffer - https://github.com/advisories/GHSA-4mjr-xmp4-gh2g

qs : qs.stringify with arrayFormat 'comma' throws an uncaught TypeError on array elements carrying a non-callable own toString (DoS) - https://github.com/advisories/GHSA-6pq8-jhm2-2vcw

fix available via `npm audit fix`

node_modules/qs

express 4.10.0 - 4.22.2 || 5.0.0-alpha.1 - 5.0.1

Depends on vulnerable versions of qs

node_modules/express

rollup <2.80.0

Severity: high

Rollup 4 has Arbitrary File Write via Path Traversal - https://github.com/advisories/GHSA-mw96-cpmx-2vgc

fix available via `npm audit fix`

node_modules/rollup

serialize-javascript <=7.1.2

Severity: high

Serialize JavaScript is Vulnerable to RCE via RegExp.flags and Date.prototype.toISOString() - https://github.com/advisories/GHSA-5c6j-r48x-rmvq

Serialize JavaScript has CPU Exhaustion Denial of Service via crafted array-like objects - https://github.com/advisories/GHSA-qj8w-gfj5-8c6v

Serialize JavaScript: Cross-site scripting (XSS) via unescaped </script at the end of a serialized function body - https://github.com/advisories/GHSA-m5mm-p8h7-m29v

fix available via `npm audit fix --force`

Will install next-pwa@3.1.5, which is a breaking change

node_modules/rollup-plugin-terser/node_modules/serialize-javascript

node_modules/serialize-javascript

rollup-plugin-terser 3.0.0 || >=4.0.4

Depends on vulnerable versions of serialize-javascript

node_modules/rollup-plugin-terser

terser-webpack-plugin 4.2.1 - 5.3.16

Depends on vulnerable versions of serialize-javascript

node_modules/terser-webpack-plugin

sharp <=0.35.5-rc.1

Severity: high

sharp inherited vulnerabilities in libvips: CVE-2026-33327, CVE-2026-33328, CVE-2026-35590, CVE-2026-35591 - https://github.com/advisories/GHSA-f88m-g3jw-g9cj

sharp: Vulnerabilities in libheif: GHSA-g89c-p67h-r497 and GHSA-2jg2-4ch7-h545 - https://github.com/advisories/GHSA-rgj7-g3m4-5g8c

sharp : Vulnerability in librsvg dependency CVE-2026-96889 - https://github.com/advisories/GHSA-wq5f-xc86-pv6w

fix available via `npm audit fix --force`

Will install sharp@0.35.5, which is a breaking change

node_modules/sharp

source-map-js 1.0.0 - 1.2.1

Severity: high

source-map-js allows event-loop denial of service through indexed source-map section offsets - https://github.com/advisories/GHSA-68fv-2mgg-jv7q

fix available via `npm audit fix`

node_modules/source-map-js

stream-json <=3.5.0

Severity: moderate

stream-json: pick/ignore/filter/replace filters are O(depth^2) on nested input — small crafted JSON blocks the event loop for seconds→minutes (DoS) - https://github.com/advisories/GHSA-528h-pc64-c93x

stream-json: JSONC parser and verifier re-scan the whole accumulated comment on every input chunk - https://github.com/advisories/GHSA-hqr4-qq8f-hg3x

stream-json has a prototype pollution issue: Assembler writes this.current[this.key] on plain objects - https://github.com/advisories/GHSA-mjw6-4jj6-33hc

fix available via `npm audit fix`

node_modules/stream-json

tar <=7.5.20

Severity: critical

node-tar Vulnerable to Arbitrary File Creation/Overwrite via Hardlink Path Traversal - https://github.com/advisories/GHSA-34x7-hfp2-rc4v

node-tar is Vulnerable to Arbitrary File Overwrite and Symlink Poisoning via Insufficient Path Sanitization - https://github.com/advisories/GHSA-8qq5-rm4j-mr97

Arbitrary File Read/Write via Hardlink Target Escape Through Symlink Chain in node-tar Extraction - https://github.com/advisories/GHSA-83g3-92jg-28cx

tar has Hardlink Path Traversal via Drive-Relative Linkpath - https://github.com/advisories/GHSA-qffp-2rhf-9h96

node-tar Symlink Path Traversal via Drive-Relative Linkpath - https://github.com/advisories/GHSA-9ppj-qmqm-q256

Race Condition in node-tar Path Reservations via Unicode Ligature Collisions on macOS APFS - https://github.com/advisories/GHSA-r6q2-hw4h-h46w

node-tar applies PAX size override to intermediary GNU long-name/long-link headers, causing tar parser interpretation differential (file smuggling) - https://github.com/advisories/GHSA-vmf3-w455-68vh

node-tar: Process crash via PAX numeric path type confusion - https://github.com/advisories/GHSA-w8wr-v893-vjvp

node-tar: Decompression/parse DoS via unlimited input - https://github.com/advisories/GHSA-23hp-3jrh-7fpw

node-tar: Negative tar entry size causes infinite loop in archive replace - https://github.com/advisories/GHSA-8x88-c5mf-7j5w

node-tar: Uncaught Exception DoS via NUL byte in PAX path/linkpath records - https://github.com/advisories/GHSA-gvwx-54wh-qm9j

node-tar: Uncontrolled recursion in mapHas/filesFilter allows uncatchable stack-overflow DoS via crafted long-path tar with member selection - https://github.com/advisories/GHSA-r292-9mhp-454m

fix available via `npm audit fix --force`

Will install firebase-tools@15.35.0, which is a breaking change

node_modules/cacache/node_modules/tar

node_modules/node-gyp/node_modules/tar

node_modules/tar

@capacitor/cli 0.0.10 - 1.1.1 || 3.0.0-alpha.0 - 7.4.5 || 8.0.0-alpha.1 - 8.0.2-nightly-20260127T151145.0

Depends on vulnerable versions of tar

node_modules/@capacitor/cli

tmp <0.2.6

Severity: high

tmp has Path Traversal via unsanitized prefix/postfix that enables directory escape - https://github.com/advisories/GHSA-ph9p-34f9-6g65

fix available via `npm audit fix`

node_modules/tmp

undici <=6.29.0

Severity: high

Use of Insufficiently Random Values in undici - https://github.com/advisories/GHSA-c76h-2ccp-4975

Undici has an unbounded decompression chain in HTTP responses on Node.js Fetch API via Content-Encoding leads to resource exhaustion - https://github.com/advisories/GHSA-g9mf-h72j-4rw9

undici Denial of Service attack via bad certificate data - https://github.com/advisories/GHSA-cxrh-j4jr-qwg3

Undici: Malicious WebSocket 64-bit length overflows parser and crashes the client - https://github.com/advisories/GHSA-f269-vfmq-vjvj

Undici has an HTTP Request/Response Smuggling issue - https://github.com/advisories/GHSA-2mjp-6q6p-2qxm

Undici has Unbounded Memory Consumption in WebSocket permessage-deflate Decompression - https://github.com/advisories/GHSA-vrm6-8vpv-qv8q

Undici has Unhandled Exception in WebSocket Client Due to Invalid server_max_window_bits Validation - https://github.com/advisories/GHSA-v9p9-hfj2-hcw8

Undici has CRLF Injection in undici via `upgrade` option - https://github.com/advisories/GHSA-4992-7rv2-5pvq

undici vulnerable to HTTP header injection via Set-Cookie percent-decoding - https://github.com/advisories/GHSA-p88m-4jfj-68fv

undici vulnerable to Set-Cookie SameSite attribute downgrade via permissive substring matching - https://github.com/advisories/GHSA-g8m3-5g58-fq7m

undici vulnerable to downstream response desynchronization via retry interceptor - https://github.com/advisories/GHSA-8xcm-r25x-g524

undici vulnerable to CRLF Injection via blob-like body 'type' property - https://github.com/advisories/GHSA-m8rv-5g2x-5cg5

undici vulnerable to cookie attribute injection via unsanitized domain and unparsed setCookie fields - https://github.com/advisories/GHSA-v3r7-h72x-cjcm

undici vulnerable to HTTP response queue poisoning via keep-alive socket reuse - https://github.com/advisories/GHSA-35p6-xmwp-9g52

undici vulnerable to downstream response splitting via retry interceptor - https://github.com/advisories/GHSA-r53p-7pc4-xj5r

undici vulnerable to Denial of Service via unrequested WebSocket subprotocol - https://github.com/advisories/GHSA-rfgv-xxqx-mfg5

undici vulnerable to Denial of Service via unbounded memory in the EventSource parser - https://github.com/advisories/GHSA-4qv8-2p9j-2685

undici vulnerable to TLS certificate validation bypass via dropped tls options in Agent - https://github.com/advisories/GHSA-2m5v-pch6-74hx

undici vulnerable to Denial of Service via TLS 1.2 certificate-changing renegotiation - https://github.com/advisories/GHSA-qrxm-fqhp-jwvm

undici WebSocket client vulnerable to Denial of Service via unbounded automatic PONG buffering - https://github.com/advisories/GHSA-9fm3-97px-rjf6

undici WebSocket client vulnerable to denial of service via fragment count bypass - https://github.com/advisories/GHSA-vxpw-j846-p89q

fix available via `npm audit fix --force`

Will install firebase@13.2.0, which is a breaking change

node_modules/undici

@firebase/auth 1.7.7-20240813205648 - 1.7.7-canary.1ff9661af || 1.7.8-20240827161511 - 1.7.9

Depends on vulnerable versions of undici

node_modules/@firebase/auth

firebase 0.900.22 || 7.9.1-0 - 7.9.1-canary.0396117e || 8.10.0-20217172214 - 8.10.0-canary.f40c0db53 || 9.0.0-20217250818 - 9.0.0-canary.d0d3acb10 || 9.0.1-2021727231341 - 9.0.1-canary.e039e1472 || 9.0.2-2021891633 - 9.0.2-canary.ff9baf70c || 9.0.3-202181503543 - 9.1.0-canary.f7d8324a1 || 9.1.1-2021830195733 - 9.1.1-canary.e70de6201 || 9.1.2-20219523556 - 9.1.2-canary.fc1d36497 || 9.22.1-20230524195328 || 10.12.2-20240523185724 - 10.12.2-canary.872e6f63e || 10.13.0-20240813205648 - 10.13.0-canary.fa0ed08fb || 10.13.1-20240827161511 - 10.14.1 || 11.9.0-20250603144652 - 11.9.0-canary.5871fd656

Depends on vulnerable versions of @firebase/auth

Depends on vulnerable versions of @firebase/auth-compat

Depends on vulnerable versions of @firebase/firestore

Depends on vulnerable versions of @firebase/firestore-compat

Depends on vulnerable versions of @firebase/functions

Depends on vulnerable versions of @firebase/functions-compat

Depends on vulnerable versions of @firebase/storage

Depends on vulnerable versions of @firebase/storage-compat

node_modules/firebase

@firebase/auth-compat 0.5.12-20240813205648 - 0.5.12-canary.fa0ed08fb || 0.5.13-20240827161511 - 0.5.14

Depends on vulnerable versions of @firebase/auth

Depends on vulnerable versions of undici

node_modules/@firebase/auth-compat

@firebase/firestore 4.7.0-20240813205648 - 4.7.0-canary.fa0ed08fb || 4.7.1-20240827161511 - 4.7.3

Depends on vulnerable versions of undici

node_modules/@firebase/firestore

@firebase/firestore-compat <=0.0.900-exp.520ca39d0 || 0.3.25-20240130223218 - 0.3.25-20240131233318 || 0.3.30-20240424141009 - 0.3.30-

dataconnect-preview.f2ddc3d7b || 0.3.35-20240813205648 - 0.3.35-canary.fa0ed08fb || 0.3.36-20240827161511 - 0.3.38

Depends on vulnerable versions of @firebase/firestore

node_modules/@firebase/firestore-compat

@firebase/functions 0.11.7-20240827161511 - 0.11.8

Depends on vulnerable versions of undici

node_modules/@firebase/functions

@firebase/functions-compat 0.3.13-20240827161511 - 0.3.14

Depends on vulnerable versions of @firebase/functions

node_modules/@firebase/functions-compat

@firebase/storage 0.13.0-20240814182916 - 0.13.0-canary.fa0ed08fb || 0.13.1-20240827161511 - 0.13.2

Depends on vulnerable versions of undici

node_modules/@firebase/storage

@firebase/storage-compat <=0.0.900-exp.520ca39d0 || 0.1.4-202192711727 - 0.1.4-canary.f27fe4304 || 0.3.10-20240814182916 - 0.3.10-canary.fa0ed08fb || 0.3.11-20240827161511 - 0.3.12

Depends on vulnerable versions of @firebase/storage

node_modules/@firebase/storage-compat

uuid <11.1.1

Severity: moderate

uuid: Missing buffer bounds check in v3/v5/v6 when buf is provided - https://github.com/advisories/GHSA-w5hq-g745-h8pq

fix available via `npm audit fix --force`

Will install firebase-admin@14.5.0, which is a breaking change

node_modules/@genkit-ai/tools-common/node_modules/uuid

node_modules/@google-cloud/logging/node_modules/uuid

node_modules/@google-cloud/storage/node_modules/uuid

node_modules/eventid/node_modules/uuid

node_modules/firebase-tools/node_modules/uuid

node_modules/gaxios/node_modules/uuid

node_modules/google-gax/node_modules/uuid

node_modules/googleapis/node_modules/uuid

node_modules/jaeger-client/node_modules/uuid

node_modules/teeny-request/node_modules/uuid

node_modules/universal-analytics/node_modules/uuid

node_modules/uuid

@genkit-ai/tools-common *

Depends on vulnerable versions of adm-zip

Depends on vulnerable versions of glob

Depends on vulnerable versions of uuid

Depends on vulnerable versions of zod

node_modules/@genkit-ai/tools-common

@google-cloud/logging 0.8.0 - 11.2.3

Depends on vulnerable versions of @google-cloud/common

Depends on vulnerable versions of eventid

Depends on vulnerable versions of uuid

node_modules/@google-cloud/logging

eventid *

Depends on vulnerable versions of uuid

node_modules/eventid

googleapis-common <=7.2.0

Depends on vulnerable versions of uuid

node_modules/googleapis/node_modules/googleapis-common

googleapis 33.0.0 - 149.0.0

Depends on vulnerable versions of googleapis-common

node_modules/googleapis

@google-cloud/opentelemetry-cloud-monitoring-exporter <=0.21.0

Depends on vulnerable versions of googleapis

node_modules/@google-cloud/opentelemetry-cloud-monitoring-exporter

jaeger-client >=3.11.0

Depends on vulnerable versions of uuid

node_modules/jaeger-client

teeny-request 3.9.1 - 9.0.0

Depends on vulnerable versions of uuid

node_modules/teeny-request

@google-cloud/common 0.32.1 - 5.0.2

Depends on vulnerable versions of retry-request

Depends on vulnerable versions of teeny-request

node_modules/@google-cloud/common

retry-request 7.0.0 - 7.0.2

Depends on vulnerable versions of teeny-request

node_modules/retry-request

universal-analytics 0.4.7 - 0.5.3

Depends on vulnerable versions of uuid

node_modules/universal-analytics

websocket-driver <=0.7.4

Severity: critical

websocket-driver: Resource limit bypass via message compression - https://github.com/advisories/GHSA-mp7j-qc5w-4988

websocket-driver: Message corruption via abuse of protocol length headers - https://github.com/advisories/GHSA-xv26-6w52-cph6

fix available via `npm audit fix`

node_modules/websocket-driver

ws 7.0.0 - 7.5.10

Severity: high

ws: Memory exhaustion DoS from tiny fragments and data chunks - https://github.com/advisories/GHSA-96hv-2xvq-fx4p

fix available via `npm audit fix`

node_modules/ws

xlsx *

Severity: high

Prototype Pollution in sheetJS - https://github.com/advisories/GHSA-4r6h-8v6p-xvw6

SheetJS Regular Expression Denial of Service (ReDoS) - https://github.com/advisories/GHSA-5pgg-2g8v-p4x9

No fix available

node_modules/xlsx

yaml 2.0.0 - 2.8.2

Severity: moderate

yaml is vulnerable to Stack Overflow via deeply nested YAML collections - https://github.com/advisories/GHSA-48c2-rrv3-qjmp

fix available via `npm audit fix`

node_modules/yaml

zod <4.6.6

Severity: high

Zod can exhaust memory while validating oversized constrained collections - https://github.com/advisories/GHSA-mrhx-c7xc-m3w5

fix available via `npm audit fix --force`

Will install zod@4.6.7, which is a breaking change

node_modules/zod

163 vulnerabilities (6 low, 97 moderate, 49 high, 11 critical)

To address issues that do not require attention, run:

npm audit fix

To address all issues possible (including breaking changes), run:

npm audit fix --force

Some issues need review, and may require choosing

a different dependency.